

RAPORT Z AUDYTU BEZPIECZEŃSTWA

Przedmiot: Audyt bezpieczeństwa

Temat projektu: Audyt bezpieczeństwa oraz hardening serwera Linux
(Ubuntu Server)

Skład zespołu: Anna Czerny i Dawid Stachiewicz

Data: Marzec 2026

Spis treści

1	Streszczenie menedżerskie	4
2	Zakres audytu	5
2.1	Elementy objęte audytem	5
2.2	Elementy wyłączone z zakresu	6
3	Metodologia audytu	6
3.1	Standardy i punkty odniesienia	7
3.2	Etapy audytu	7
3.3	Podejście do dokumentowania podatności	8
4	Opis środowiska testowego	9
4.1	Topologia środowiska	9
4.2	Specyfikacja systemu audytowanego	9
4.3	Specyfikacja systemu audytującego	10
4.4	Konfiguracja pamięci masowej systemu Ubuntu	10
4.5	Konfiguracja SSH podczas instalacji	11
4.6	Identyfikacja podstawowej konfiguracji systemu	12
5	Narzędzia wykorzystane w audycie	12
5.1	Uzasadnienie doboru narzędzi	14
6	Wyniki audytu	14
6.1	Identyfikacja zasobów i usług	15
6.1.1	Instalacja usług	15
6.1.2	Weryfikacja aktywnych usług po instalacji	16
6.1.3	Analiza statusu usług	17
6.1.4	Podsumowanie identyfikacji zasobów	18
6.2	Przygotowanie systemu audytującego	19
6.2.1	Instalacja narzędzi audytowych	19

6.2.2	Konfiguracja i inicjalizacja środowiska GVM/OpenVAS	20
6.2.3	Weryfikacja gotowości środowiska	21
6.3	Rekonesans usług przy użyciu Nmap	21
6.3.1	Metodyka skanowania	22
6.3.2	Wyniki skanowania	22
6.3.3	Analiza wyników rekonesansu	23
6.3.4	Weryfikacja dostępności usługi HTTP	23
6.3.5	Wnioski z rekonesansu	24
6.4	Uruchomienie i konfiguracja OpenVAS	24
6.4.1	Dodanie hosta audytowanego	25
6.4.2	Konfiguracja zadania skanowania	25
6.5	Stan początkowy systemu – audyt wyjściowy	27
6.6	Symulacja podatności	30
6.6.1	Zakres wprowadzonych zmian	30
6.6.2	Wyniki skanu po symulacji podatności	30
6.7	SSH Brute Force Logins With Default Credentials	33
6.8	Anonymous FTP Login	34
6.9	FTP Unencrypted Cleartext Login	35
6.10	Podatności niskiego poziomu ryzyka	36
7	Tabela podatności (Vulnerability Summary)	37
8	Analiza ryzyka	38
8.1	Omówienie wyników analizy ryzyka	39
9	Rekomendacje bezpieczeństwa	39
10	Re-audyt (weryfikacja po poprawkach)	42
10.1	Przebieg re-audytu	42
10.2	Wyniki re-audytu	44
10.3	Ocena skuteczności hardeningu	44

11 Wnioski końcowe	45
12 Załączniki	46

1. Streszczenie menedżerskie

Celem przeprowadzonego audytu było określenie aktualnego poziomu bezpieczeństwa systemu Ubuntu Server działającego w środowisku maszyn wirtualnych oraz wskazanie obszarów wymagających poprawy. Audyt miał charakter praktyczny i został przeprowadzony w warunkach laboratoryjnych, jednak z zachowaniem podejścia zbliżonego do rzeczywistej oceny bezpieczeństwa infrastruktury serwerowej. Przedmiotem analizy była zarówno konfiguracja systemu operacyjnego, jak i sposób działania uruchomionych usług sieciowych, które mogły stanowić potencjalny punkt wejścia dla atakującego.

W ramach prac wykonano rozpoznanie środowiska, identyfikację dostępnych usług, analizę podatności, ocenę ryzyka oraz wdrożenie działań naprawczych w postaci hardeningu systemu. Istotnym elementem projektu było również kontrolowane osłabienie wybranych mechanizmów bezpieczeństwa, tak aby możliwe było praktyczne wykazanie wpływu błędnej konfiguracji na poziom bezpieczeństwa badanego serwera. Dzięki temu raport nie ogranicza się wyłącznie do przedstawienia bezpiecznego stanu systemu, lecz pokazuje także, jakie konsekwencje mogą wynikać z niewłaściwego zarządzania usługami, uwierzytelnianiem oraz dostępem sieciowym.

Analiza stanu początkowego wykazała, że system po podstawowej instalacji i konfiguracji nie zawierał podatności wysokiego ryzyka, a wykryte problemy miały głównie charakter informacyjny. Oznaczało to, że wyjściowa konfiguracja serwera była względnie poprawna, choć nadal wymagała dalszego wzmacniania zgodnie z dobrymi praktykami bezpieczeństwa. Na dalszym etapie celowo wprowadzono wybrane słabości konfiguracyjne, aby sprawdzić, czy narzędzia audytowe poprawnie wykryją istotne zagrożenia oraz czy możliwe będzie późniejsze potwierdzenie skuteczności działań naprawczych.

W wyniku przeprowadzonego skanowania podatności po osłabieniu konfiguracji wykazano występowanie zagrożeń o różnym poziomie krytyczności, w tym podatności krytycznej związanej z usługą zdalnego dostępu oraz podatności średnich dotyczących usługi transferu plików. Taki wynik potwierdził, że nawet pozornie niewielkie zmiany konfiguracyjne mogą istotnie obniżyć poziom bezpieczeństwa systemu i zwiększyć ryzyko nieautoryzowanego dostępu, ujawnienia danych lub przejęcia kontroli nad usługami.

W odpowiedzi na wykryte problemy wdrożono zestaw działań hardeningowych obejmujących między innymi ograniczenie sposobu logowania do systemu, poprawę ustawień usług sieciowych, zawężenie dostępu do bazy danych, konfigurację zapory sieciowej oraz uruchomienie dodatkowych mechanizmów ochrony przed próbami nieautoryzowanego dostępu. Działania te miały na celu nie tylko usunięcie wykrytych podatności, ale również zmniejszenie ogólnej powierzchni ataku i podniesienie odporności systemu na typowe zagrożenia.

Końcowy re-audyt wykazał wyraźną poprawę poziomu bezpieczeństwa badanego środo-

wiska. Podatności krytyczne i średnie zostały wyeliminowane, a w systemie pozostały jedynie podatności niskiego poziomu ryzyka, które nie stanowią bezpośredniego zagrożenia dla integralności ani dostępności usług. Otrzymane wyniki potwierdzają, że właściwie przeprowadzony hardening ma bezpośredni i mierzalny wpływ na poprawę bezpieczeństwa systemu Linux.

Z perspektywy organizacyjnej projekt potwierdza, że regularny audyt bezpieczeństwa, połączony z analizą ryzyka i wdrażaniem działań naprawczych, powinien stanowić stały element utrzymania systemów serwerowych. Nawet w niewielkim środowisku testowym widoczne było, że brak odpowiednich zabezpieczeń może szybko doprowadzić do powstania poważnych zagrożeń, natomiast konsekwentne wdrażanie dobrych praktyk administracyjnych pozwala te zagrożenia skutecznie ograniczyć.

2. Zakres audytu

Audyt objął system Ubuntu Server 24.04 LTS uruchomiony jako maszyna wirtualna w środowisku VMware oraz działające w nim usługi sieciowe. Analizie poddano konfigurację systemu operacyjnego, aktywne usługi sieciowe, mechanizmy uwierzytelniania, politykę dostępu sieciowego oraz wybrane elementy infrastruktury serwerowej. Celem audytu było określenie aktualnego poziomu bezpieczeństwa badanego systemu, identyfikacja podatności oraz weryfikacja skuteczności wdrożonych działań naprawczych.

2.1. Elementy objęte audytem

Zakres audytu obejmował następujące obszary:

- **Identyfikację aktywnych usług i portów** – weryfikację wszystkich nasłuchujących usług sieciowych oraz otwartych portów TCP/UDP z poziomu sieci laboratoryjnej przy użyciu narzędzia Nmap. Analiza obejmowała identyfikację wersji oprogramowania oraz wykrywanie potencjalnych wektorów ataku.
- **Skanowanie podatności** – automatyczne skanowanie systemu narzędziem OpenVAS/GVM w celu identyfikacji znanych podatności w zainstalowanych usługach, pakietach systemowych oraz konfiguracji. Skan przeprowadzono trzykrotnie: w stanie początkowym, po celowym osłabieniu konfiguracji oraz po wdrożeniu hardeningu.
- **Analizę konfiguracji usług sieciowych** – szczegółową ocenę ustawień usług SSH (OpenSSH 9.6p1), HTTP (Nginx 1.24.0), FTP (vsftpd 3.0.5) oraz bazy danych MariaDB (10.11.14) pod kątem zgodności z dobrymi praktykami bezpieczeństwa i rekomendacjami producentów.

- **Weryfikację mechanizmów uwierzytelniania** – ocenę polityki haseł, sposobu logowania do usługi SSH, możliwości logowania konta uprzywilejowanego (**root**) oraz podatności na ataki typu brute force.
- **Analizę konfiguracji zapory sieciowej** – ocenę reguł UFW pod kątem zasady minimalnego dostępu, blokowania zbędnych portów oraz ograniczenia powierzchni ataku.
- **Symulację podatności** – celowe wprowadzenie słabości konfiguracyjnych w celu praktycznego wykazania wpływu błędnej konfiguracji na poziom bezpieczeństwa systemu i weryfikacji skuteczności narzędzi audytowych.
- **Wdrożenie i weryfikację hardeningu** – implementację działań naprawczych oraz przeprowadzenie re-audytu potwierdzającego skuteczność wprowadzonych zabezpieczeń.

2.2. Elementy wyłączone z zakresu

Poniższe obszary zostały celowo wyłączone z zakresu niniejszego audytu:

- testowanie logiki aplikacji webowych działających na serwerze (walidacja danych wejściowych, autoryzacja użytkowników),
- ataki na warstwę sieciową wykraczające poza środowisko laboratoryjne,
- analiza bezpieczeństwa fizycznego środowiska serwerowego,
- konfiguracja systemu operacyjnego hosta VMware w zakresie niezwiązanym bezpośrednio z audytowaną maszyną wirtualną,
- testy socjotechniczne i phishing,
- audyt innych systemów działających w sieci laboratoryjnej.

Wymienione obszary wymagałyby odrębnych testów wykraczających poza cel i ramy czasowe niniejszego audytu.

3. Metodologia audytu

Audyt został przeprowadzony w modelu **white-box**, ponieważ audytujący posiadał pełny dostęp administracyjny do badanej maszyny wirtualnej, w tym dostęp do konfiguracji systemu operacyjnego, plików konfiguracyjnych usług oraz logów systemowych. Wybór tej

metody był podyktowany charakterem projektu – celem nie było wyłącznie wykrycie podatności widocznych z zewnątrz, lecz kompleksowa ocena bezpieczeństwa całego środowiska serwerowego, obejmująca zarówno warstwę sieciową, jak i konfigurację wewnętrzną systemu.

Podejście white-box pozwoliło na kontrolowane wprowadzanie zmian konfiguracyjnych, symulację rzeczywistych podatności oraz ich późniejsze usunięcie, co umożliwiło pełną weryfikację skuteczności wdrożonych zabezpieczeń w ramach re-audytu.

3.1. Standardy i punkty odniesienia

Podczas przeprowadzania audytu korzystano z następujących standardów i rekomendacji branżowych:

- **CIS Benchmarks for Ubuntu Linux** – zestaw wytycznych dotyczących bezpiecznej konfiguracji systemu operacyjnego Ubuntu, obejmujący m.in. zarządzanie kontami użytkowników, konfigurację usług sieciowych oraz politykę logowania.
- **OWASP Testing Guide** – metodyka testowania bezpieczeństwa aplikacji i infrastruktury, wykorzystana przy ocenie ryzyka i klasyfikacji podatności.
- **Common Vulnerability Scoring System (CVSS) v3.1** – standardowy system oceny krytyczności podatności, zastosowany do wyceny każdego wykrytego zagrożenia.
- **Common Vulnerabilities and Exposures (CVE)** – baza znanych podatności, wykorzystana podczas analizy wyników skanowania OpenVAS.

3.2. Etapy audytu

Proces audytu został podzielony na osiem następujących po sobie etapów:

1. **Przygotowanie środowiska testowego** – instalacja i konfiguracja maszyn wirtualnych Ubuntu Server 24.04 oraz Kali Linux w izolowanej sieci Host-Only. Weryfikacja łączności sieciowej między maszynami oraz poprawności działania środowiska przed przystąpieniem do testów.
2. **Instalacja i konfiguracja usług** – wdrożenie na audytowanym serwerze dodatkowych usług sieciowych (Nginx, MariaDB, vsftpd) w celu odwzorowania realistycznego środowiska serwerowego. Zebranie informacji o wersjach zainstalowanego oprogramowania.

3. **Rekonesans i enumeracja usług sieciowych** – aktywne skanowanie audytowanego hosta narzędziem Nmap w celu identyfikacji otwartych portów, działających usług oraz ich wersji. Na tym etapie odwzorowano perspektywę potencjalnego atakującego przeprowadzającego rozpoznanie środowiska.
4. **Skanowanie podatności** – przeprowadzenie automatycznego skanowania narzędziem OpenVAS/GVM. Skonfigurowano zadanie skanowania z profilem *Full and Fast* obejmującym pełny zakres testów dostępnych w bazie NVT (Network Vulnerability Tests). Wyniki pierwszego skanu posłużyły jako punkt odniesienia (baseline) dla dalszych etapów audytu.
5. **Analiza wyników i identyfikacja podatności** – ocena raportów wygenerowanych przez OpenVAS, klasyfikacja wykrytych podatności według poziomu ryzyka CVSS oraz analiza potencjalnego wpływu każdej z nich na bezpieczeństwo systemu. Na tym etapie określono również priorytety działań naprawczych.
6. **Symulacja podatności** – celowe osłabienie wybranych mechanizmów bezpieczeństwa w celu praktycznego wykazania wpływu błędnej konfiguracji na poziom bezpieczeństwa systemu. Zmiany obejmowały konfigurację usługi SSH dopuszczającą logowanie słabym hasłem oraz uruchomienie podatnej konfiguracji serwera FTP z włączonym dostępem anonimowym. Następnie przeprowadzono ponowne skanowanie OpenVAS w celu potwierdzenia wykrycia wprowadzonych podatności.
7. **Wdrożenie hardeningu systemu** – implementacja działań naprawczych eliminujących wykryte podatności. Zakres hardeningu obejmował zabezpieczenie usługi SSH, zmianę polityki haseł, konfigurację zapory sieciowej UFW, ograniczenie dostępu do bazy danych MariaDB, zabezpieczenie usługi FTP oraz wdrożenie narzędzia Fail2ban chroniącego przed atakami brute force.
8. **Re-audit** – ponowne przeprowadzenie skanowania OpenVAS na poprawionym systemie przy użyciu tych samych narzędzi i konfiguracji co w audycie pierwotnym. Celem re-auditów było potwierdzenie skuteczności wdrożonych zabezpieczeń oraz udokumentowanie zmian w profilu ryzyka systemu.

3.3. Podejście do dokumentowania podatności

Każda zidentyfikowana podatność została udokumentowana według jednolitego schematu obejmującego:

- identyfikator podatności oraz powiązane numery CVE,
- poziom ryzyka zgodny z metryką CVSS v3.1,

- opis techniczny mechanizmu podatności,
- dowód wystąpienia podatności w postaci wyników narzędzi audytowych,
- ocenę wpływu biznesowego w przypadku wykorzystania podatności,
- konkretną rekomendację naprawczą.

Takie podejście zapewnia kompletność dokumentacji i umożliwia jednoznaczną weryfikację statusu każdej podatności w ramach re-audytu.

4. Opis środowiska testowego

Środowisko laboratoryjne zostało uruchomione z wykorzystaniem platformy VMware Workstation. Zastosowanie wirtualizacji pozwoliło na stworzenie izolowanego środowiska testowego, w którym możliwe było bezpieczne przeprowadzanie testów bez ryzyka wpływu na inne zasoby sieciowe. W projekcie wykorzystano dwie maszyny wirtualne działające w tej samej izolowanej sieci.

4.1. Topologia środowiska

Obie maszyny wirtualne zostały połączone w izolowanej sieci typu **Host-Only**, co oznacza, że komunikacja sieciowa między nimi odbywała się wyłącznie w obrębie środowiska wirtualnego, bez dostępu do zewnętrznej sieci. Takie rozwiązanie eliminuje ryzyko przypadkowego oddziaływania testów na inne systemy oraz zapewnia powtarzalność wyników.

Maszyna	System operacyjny	Rola
Ubuntu Server	Ubuntu Server 24.04 LTS	System audytowany – serwer docelowy, na którym uruchomiono usługi sieciowe będące przedmiotem audytu
Kali Linux	Kali Linux (aktualna)	System audytujący – stacja robocza audytora, z której przeprowadzano rekonesans i skanowanie podatności

4.2. Specyfikacja systemu audytowanego

Audytowany serwer Ubuntu Server 24.04 LTS został skonfigurowany z następującymi parametrami:

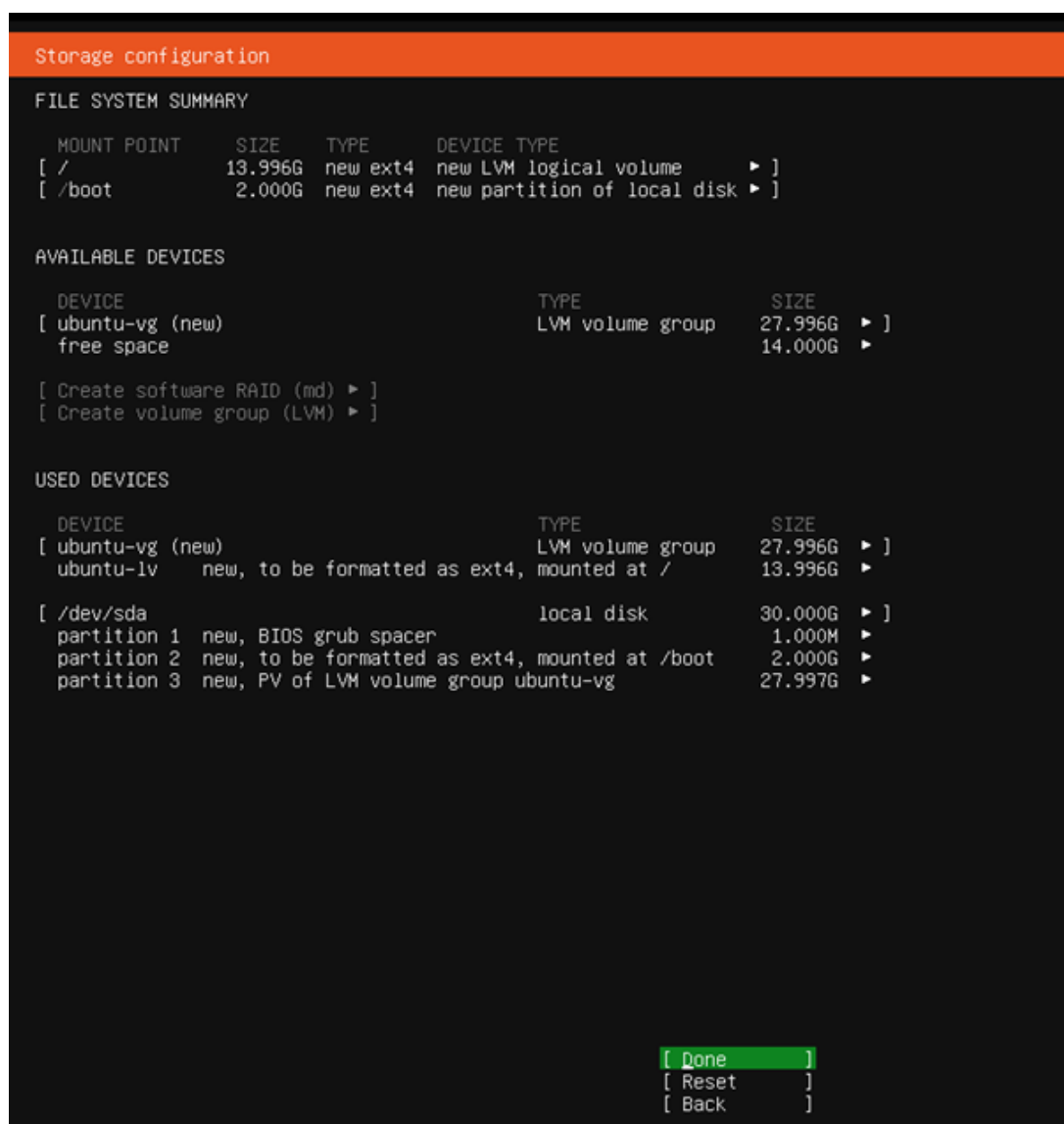
Parametr	Wartość
System operacyjny	Ubuntu Server 24.04 LTS
Adres IP	192.168.146.128
Interfejs sieciowy	ens33 (VMware Host-Only)
Układ partycji	LVM – osobna partycja /boot (2 GB) oraz wolumin logiczny na system główny (14 GB)
Usługi sieciowe	OpenSSH 9.6p1, Nginx 1.24.0, MariaDB 10.11.14, vsftpd 3.0.5
Użytkownik administracyjny	dawid (sudo)

4.3. Specyfikacja systemu audytującego

System audytujący Kali Linux pełnił rolę stacji roboczej audytora. Zainstalowano na nim narzędzia niezbędne do przeprowadzenia rekonesansu oraz skanowania podatności, w tym pakiet GVM/OpenVAS oraz Nmap. Kali Linux jest dystrybucją dedykowaną do testów penetracyjnych i audytów bezpieczeństwa, zawierającą w standardowej instalacji szeroki zestaw narzędzi audytowych.

4.4. Konfiguracja pamięci masowej systemu Ubuntu

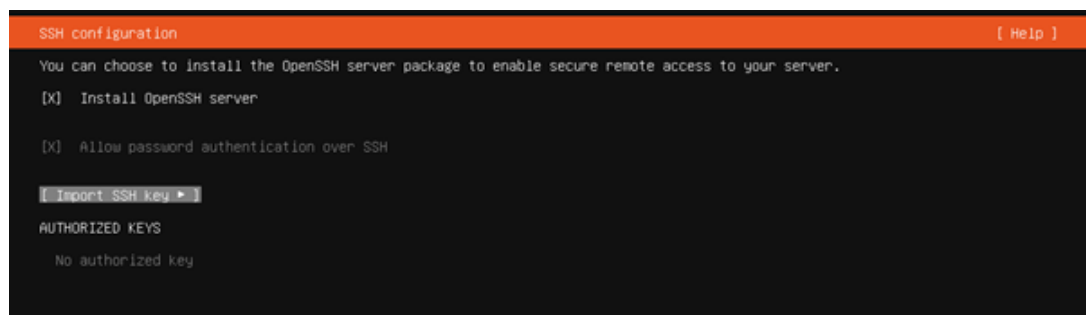
Podczas instalacji Ubuntu Server wykorzystano układ partycji oparty na menedżerze woluminów logicznych LVM (Logical Volume Manager). Zastosowanie LVM umożliwia elastyczne zarządzanie przestrzenią dyskową oraz łatwe rozszerzanie woluminów w przyszłości. Utworzono osobną partycję /boot o rozmiarze 2 GB oraz logiczny wolumin przeznaczony na system główny o rozmiarze 14 GB, zamontowany w katalogu głównym (/).



Rysunek 1: Konfiguracja przestrzeni dyskowej podczas instalacji Ubuntu Server

4.5. Konfiguracja SSH podczas instalacji

Na etapie instalacji systemu włączono usługę OpenSSH Server oraz dopuszczono uwierzytelnianie hasłem. Decyzja ta była celowa – obecność usługi SSH z uwierzytelnianiem hasłem stanowiła punkt wyjścia do późniejszej analizy bezpieczeństwa zdalnego dostępu. W rzeczywistych środowiskach produkcyjnych zaleca się stosowanie wyłącznie uwierzytelniania kluczem publicznym, co zostało uwzględnione w rekomendacjach hardeningu opisanych w dalszej części raportu.



Rysunek 2: Konfiguracja usługi SSH podczas instalacji Ubuntu Server

4.6. Identyfikacja podstawowej konfiguracji systemu

Po zakończeniu instalacji zweryfikowano adresację sieciową oraz porty nasłuchujące przy użyciu poleceń `ip a` oraz `ss -tulnp`. Na tym etapie aktywna była jedynie usługa SSH nasłuchująca na porcie 22/TCP, co potwierdzało czysty stan systemu przed instalacją dodatkowych usług. Adres IP serwera przydzielony przez VMware w sieci Host-Only wynosił 192.168.146.128.

```

david@ubuntu-audit:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:d1:64:b2 brd ff:ff:ff:ff:ff:ff
    altname ens3
    inet 192.168.146.128/24 metric 100 brd 192.168.146.255 scope global dynamic ens33
        valid_lft 1675sec preferred_lft 1675sec
    inet6 fe80::20c:29ff:fe64:b2 scope link
        valid_lft forever preferred_lft forever
david@ubuntu-audit:~$ ss -tulnp
Netid      State     Recv-Q      Send-Q      Local Address:Port      Peer Address:Port      Process
udp        UNCONN    0           0           127.0.0.54:53            0.0.0.0:*               *
udp        UNCONN    0           0           127.0.0.53:53            0.0.0.0:*               *
udp        UNCONN    0           0           192.168.146.128:53:68    0.0.0.0:*               *
tcp        LISTEN    0           4096        127.0.0.53:53            0.0.0.0:*               *
tcp        LISTEN    0           4096        127.0.0.54:53            0.0.0.0:*               *
tcp        LISTEN    0           4096        0.0.0.0:22               0.0.0.0:*               sshd
tcp        LISTEN    0           4096        [::]:22                  [::]:*                  *

```

Rysunek 3: Adres IP serwera Ubuntu oraz aktywne porty po podstawowej instalacji systemu

5. Narzędzia wykorzystane w audycie

W trakcie audytu wykorzystano zestaw narzędzi dedykowanych do testów bezpieczeństwa infrastruktury serwerowej. Dobór narzędzi był podyktowany charakterem audytowanego środowiska – systemem Linux z aktywnymi usługami sieciowymi. Poniżej przedstawiono szczegółowy opis każdego z zastosowanych narzędzi wraz z uzasadnieniem jego wyboru.

Narzędzie	Wersja	Zastosowanie
-----------	--------	--------------

Nmap	7.98	Rekonesans sieciowy, identyfikacja otwartych portów TCP/UDP, wykrywanie wersji działających usług oraz identyfikacja systemu operacyjnego. Nmap stanowił pierwszy etap rozpoznania środowiska.
OpenVAS / GVM	–	Automatyczne skanowanie podatności w oparciu o bazę NVT (Network Vulnerability Tests). Narzędzie wykorzystano trzykrotnie: w stanie wyjściowym, po symulacji podatności oraz po wdrożeniu hardeningu.
Lynis	–	Lokalny audyt konfiguracji systemu operacyjnego przeprowadzany bezpośrednio na audytowanej maszynie. Lynis weryfikuje ustawienia systemu zgodnie z wytycznymi CIS i dostarcza szczegółowych rekomendacji hardeningowych.
UFW	–	Konfiguracja i zarządzanie zaporą sieciową systemu Ubuntu. UFW (Uncomplicated Firewall) stanowi warstwę ochronną ograniczającą dostęp sieciowy do systemu wyłącznie do niezbędnych portów.
Fail2ban	–	Narzędzie do automatycznej ochrony przed atakami brute force. Monitoruje logi systemowe i blokuje adresy IP przekraczające zdefiniowany próg nieudanych prób logowania.
OpenSSH	9.6p1	Usługa zdalnego dostępu administracyjnego będąca głównym przedmiotem analizy bezpieczeństwa. Konfiguracja OpenSSH była kluczowym elementem zarówno symulacji podatności, jak i procesu hardeningu.
Nginx	1.24.0	Serwer HTTP wystawiony na port 80/TCP w celu odwzorowania realistycznego środowiska serwerowego. Nginx zastąpił Apache2, który nie uruchomił się z powodu konfliktu na porcie 80/TCP.

MariaDB	10.11.14	Relacyjna baza danych analizowana pod kątem ekspozycji sieciowej oraz bezpieczeństwa konfiguracji. W ramach hardeningu ograniczono nasłuchiwanie usługi wyłącznie do interfejsu lokalnego.
vsftpd	3.0.5	Serwer FTP wykorzystany do demonstracji podatności związanych z nieszyfrowanym transferem danych oraz anonimowym dostępem. Celowo skonfigurowany w sposób podatny w celu weryfikacji skuteczności narzędzi audytowych.

5.1. Uzasadnienie doboru narzędzi

Nmap i OpenVAS stanowią standardowy zestaw narzędzi stosowany w audytach infrastruktury sieciowej. Nmap dostarcza szybkiego i precyzyjnego obrazu powierzchni ataku widzianej z zewnątrz, natomiast OpenVAS przeprowadza głęboką analizę podatności w oparciu o regularnie aktualizowaną bazę zagrożeń. Połączenie obu narzędzi pozwala na kompleksową ocenę bezpieczeństwa systemu – od poziomu sieciowego aż po konkretne podatności w wersjach oprogramowania.

Lynis uzupełnia obraz o perspektywę wewnętrzną systemu, identyfikując słabości konfiguracyjne niewidoczne ze skanu sieciowego, takie jak nieprawidłowe uprawnienia do plików, niezabezpieczone parametry jądra czy braki w polityce haseł.

UFW i Fail2ban weszły w skład wdrożonego hardeningu jako narzędzia bezpośrednio adresujące wykryte podatności – zaporę sieciową ogranicza dostęp do usług, a Fail2ban eliminuje ryzyko skutecznego ataku brute force na usługę SSH.

6. Wyniki audytu

Niniejszy rozdział przedstawia kompletne wyniki przeprowadzonego audytu bezpieczeństwa systemu Ubuntu Server. Obejmuje on kolejne etapy prac audytowych – od identyfikacji zasobów i usług, przez rekonesans sieciowy i konfigurację narzędzi skanujących, aż po szczegółową analizę wykrytych podatności wraz z ich opisem technicznym, dowodem wystąpienia oraz oceną wpływu biznesowego.

6.1. Identyfikacja zasobów i usług

W celu odwzorowania realistycznego środowiska serwerowego na systemie Ubuntu Server zainstalowano dodatkowe usługi sieciowe. Decyzja o wyborze konkretnych usług była podyktowana ich powszechnym występowaniem w rzeczywistych środowiskach produkcyjnych – serwer HTTP, baza danych oraz usługa transferu plików stanowią typowy zestaw komponentów infrastruktury serwerowej. Każda z usług reprezentuje inną klasę potencjalnych zagrożeń, co pozwoliło na przeprowadzenie audytu obejmującego różnorodne wektory ataku.

6.1.1. Instalacja usług

Instalację usług przeprowadzono przy użyciu menedżera pakietów apt. W pierwszej kolejności zainstalowano serwer Apache2, jednak z uwagi na konflikt portu 80/TCP z później instalowanym Nginx, Apache2 nie uruchomił się poprawnie i nie pełnił roli aktywnej usługi HTTP w trakcie audytu. Funkcję serwera WWW przejął Nginx, który poprawnie zajął port 80/TCP. Następnie zainstalowano serwer bazy danych MariaDB oraz serwer FTP vsftpd.

```
dawid@ubuntu-audit:~$ sudo apt install apache2 -y
[sudo] password for dawid:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  apache2-bin apache2-data apache2-utils libapr1t64 libaprutil1-dbd-sqlite3 libaprutil1-ldap libaprutil1t64
  liblua5.4-0 ssl-cert
Suggested packages:
  apache2-doc apache2-suexec-pristine | apache2-suexec-custom www-browser
The following NEW packages will be installed:
  apache2 apache2-bin apache2-data apache2-utils libapr1t64 libaprutil1-dbd-sqlite3 libaprutil1-ldap libaprutil1t64
  liblua5.4-0 ssl-cert
0 upgraded, 10 newly installed, 0 to remove and 0 not upgraded.
```

Rysunek 4: Instalacja serwera Apache2 w systemie Ubuntu

```
dawid@ubuntu-audit:~$ sudo apt install nginx -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  nginx-common
Suggested packages:
  fcgiwrap nginx-doc
The following NEW packages will be installed:
  nginx nginx-common
0 upgraded, 2 newly installed, 0 to remove and 0 not upgraded.
```

Rysunek 5: Instalacja serwera Nginx w systemie Ubuntu


```
dawid@ubuntu-audit:~$ sudo apt install mariadb-server -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  galera-4 libcgi-fast-perl libcgi-pm-perl libclone-perl libconfig-
  libhtml-tagset-perl libhtml-template-perl libhttp-date-perl lib
  mariadb-client mariadb-client-core mariadb-common mariadb-plugin
  mariadb-server-core mysql-common pv socat
Suggested packages:
  libmldbm-perl libnet-daemon-perl libsql-statement-perl libdata-
The following NEW packages will be installed:
  galera-4 libcgi-fast-perl libcgi-pm-perl libclone-perl libconfig-
  libhtml-tagset-perl libhtml-template-perl libhttp-date-perl lib
  mariadb-client mariadb-client-core mariadb-common mariadb-plugin
  mariadb-server mariadb-server-core mysql-common pv socat
0 upgraded, 37 newly installed, 0 to remove and 0 not upgraded.
```

Rysunek 6: Instalacja serwera MariaDB w systemie Ubuntu

6.1.2. Weryfikacja aktywnych usług po instalacji

Po zakończeniu instalacji zweryfikowano stan aktywnych usług oraz nasłuchujących portów przy użyciu polecenia `ss -tulnp`. Wyniki potwierdziły obecność następujących usług sieciowych:

- **SSH** – port 22/TCP, usługa OpenSSH 9.6p1 nasłuchująca na wszystkich interfejsach sieciowych,
- **HTTP** – port 80/TCP, serwer Nginx 1.24.0 obsługujący ruch HTTP,
- **MariaDB/MySQL** – port 3306/TCP, serwer bazy danych nasłuchujący na interfejsie lokalnym (127.0.0.1),
- **systemd-resolved** – port 53/UDP, lokalny resolver DNS systemu operacyjnego.

```
dawid@ubuntu-audit:~$ ss -tulnp
```

NetId	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port	Process
udp	UNCONN	0	0	127.0.0.0:53	0.0.0.0:*	
udp	UNCONN	0	0	127.0.0.53:53	0.0.0.0:*	
udp	UNCONN	0	0	192.168.168.128:53	0.0.0.0:*	
tcp	LISTEN	0	65536	127.0.0.53:53	0.0.0.0:*	
tcp	LISTEN	0	65536	127.0.0.0:1	0.0.0.0:*	
tcp	LISTEN	0	65536	127.0.0.1:3306	0.0.0.0:*	
tcp	LISTEN	0	65536	0.0.0.0:22	0.0.0.0:*	
tcp	LISTEN	0	65536	:::22	:::*	

```
dawid@ubuntu-audit:~$
```

Rysunek 7: Lista aktywnych usług po instalacji serwerów Apache, Nginx i MariaDB

6.1.3. Analiza statusu usług

Dla każdej zainstalowanej usługi zweryfikowano jej status przy użyciu polecenia `systemctl status`. Analiza statusu pozwoliła potwierdzić poprawność działania usług oraz zebrać informacje o wersjach oprogramowania i czasie uruchomienia.

Apache2 – usługa nie uruchomiła się poprawnie z powodu konfliktu portu 80/TCP z serwerem Nginx. Status *failed* wynikał z faktu, że Nginx zajął port 80/TCP jako pierwszy. Apache2 pozostał zainstalowany w systemie, jednak nie był aktywny podczas przeprowadzania audytu i nie stanowił powierzchni ataku.

```
dawid@ubuntu-audit:~$ systemctl status apache2
* apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: enabled)
   Active: failed (Result: exit-code) since Thu 2026-03-05 20:31:36 UTC; 33s ago
     Docs: https://httpd.apache.org/docs/2.4/
   Process: 1352 ExecStart=/usr/sbin/apachectl start (code=exited, status=1/FAILURE)
      CPU: 29ms

Mar 05 20:31:36 ubuntu-audit systemd[1]: Starting apache2.service - The Apache HTTP Server...
Mar 05 20:31:36 ubuntu-audit apachectl[1371]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name: /etc/hostname
Mar 05 20:31:36 ubuntu-audit apachectl[1371]: (98)Address already in use: AH00072: make_sock: could not bind to address 0.0.0.0:80
Mar 05 20:31:36 ubuntu-audit apachectl[1371]: (98)Address already in use: AH00072: make_sock: could not bind to address 0.0.0.0:80
Mar 05 20:31:36 ubuntu-audit apachectl[1371]: no listening sockets available, shutting down
Mar 05 20:31:36 ubuntu-audit apachectl[1371]: AH00015: Unable to open logs
Mar 05 20:31:36 ubuntu-audit systemd[1]: apache2.service: Control process exited, code=exited, status=1/FAILURE
Mar 05 20:31:36 ubuntu-audit systemd[1]: apache2.service: Failed with result 'exit-code'.
Mar 05 20:31:36 ubuntu-audit systemd[1]: Failed to start apache2.service - The Apache HTTP Server.
lines 1-16/16 (END)
```

Rysunek 8: Status usługi Apache2

Nginx – usługa działała poprawnie ze statusem *active (running)*. Nginx obsługiwał ruch HTTP na porcie 80/TCP i był dostępny z poziomu sieci laboratoryjnej, co potwierdzono weryfikacją z poziomu przeglądarki internetowej na maszynie Kali Linux.

```
dawid@ubuntu-audit:~$ systemctl status nginx
● nginx.service - A high performance web server and a reverse proxy server
   Loaded: loaded (/usr/lib/systemd/system/nginx.service; enabled; preset: enabled)
   Active: active (running) since Thu 2026-03-05 20:31:36 UTC; 1min 2s ago
     Docs: man:nginx(8)
   Process: 1357 ExecStartPre=/usr/sbin/nginx -t -q -g daemon on; master_process on; (code=exited, status=0/SUCCESS)
   Process: 1373 ExecStart=/usr/sbin/nginx -g daemon on; master_process on; (code=exited, status=0/SUCCESS)
   Main PID: 1377 (nginx)
      Tasks: 3 (limit: 4545)
     Memory: 3.7M (peak: 3.8M)
        CPU: 14ms
    CGroup: /system.slice/nginx.service
            └─1377 "nginx: master process /usr/sbin/nginx -g daemon on; master_process on;"
              └─1378 "nginx: worker process"
                └─1379 "nginx: worker process"

Mar 05 20:31:36 ubuntu-audit systemd[1]: Starting nginx.service - A high performance web server and a reverse proxy server...
Mar 05 20:31:36 ubuntu-audit systemd[1]: Started nginx.service - A high performance web server and a reverse proxy server.
lines 1-17/17 (END)
```

Rysunek 9: Status usługi Nginx

MariaDB – usługa działała poprawnie ze statusem *active (running)*. Serwer bazy danych nasłuchiwał na porcie 3306/TCP, jednak wyłącznie na interfejsie lokalnym (127.0.0.1), co oznaczało, że w stanie początkowym nie był dostępny z poziomu sieci zewnętrznej. Port 3306/TCP był widoczny w skanach Nmap jako zamknięty z perspektywy sieci.

```
david@ubuntu-audit:~$ systemctl status mariadb
● mariadb.service - MariaDB 10.11.14 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; enabled; preset: enabled)
   Active: active (running) since Thu 2026-03-05 20:31:36 UTC; 2min 45s ago
     Docs: man:mariadb(8)
           https://mariadb.com/kb/en/library/systemd/
   Process: 799 ExecStartPre=/usr/bin/install -m 755 -o mysql -g root -d /var/run/mysqld (code=exited, status=0/SUCCESS)
   Process: 840 ExecStartPre=/bin/sh -c systemctl unset-environment _WSREP_START_POSITION (code=exited, status=0/SUCCESS)
   Process: 939 ExecStartPre=/bin/sh -c [ ! -e /usr/bin/galera_recovery ] && VAR= || VAR="/usr/bin/galera_recovery";>
   Process: 1297 ExecStartPost=/bin/sh -c systemctl unset-environment _WSREP_START_POSITION (code=exited, status=0/SUCCESS)
   Process: 1299 ExecStartPost=/etc/mysql/debian-start (code=exited, status=0/SUCCESS)
 Main PID: 1115 (mariadb)
   Status: "Taking your SQL requests now..."
    Tasks: 10 (limit: 30000)
  Memory: 112.0M (peak: 115.1M)
     CPU: 487ms
    CGroup: /system.slice/mariadb.service
            └─1115 /usr/sbin/mariadb

Mar 05 20:31:36 ubuntu-audit mariadb[1115]: 2026-03-05 20:31:36 0 [Note] Plugin 'FEEDBACK' is disabled.
Mar 05 20:31:36 ubuntu-audit mariadb[1115]: 2026-03-05 20:31:36 0 [Note] InnoDB: Buffer pool(s) load completed at 2603
Mar 05 20:31:36 ubuntu-audit mariadb[1115]: 2026-03-05 20:31:36 0 [Warning] You need to use --log-bin to make --expire
Mar 05 20:31:36 ubuntu-audit mariadb[1115]: 2026-03-05 20:31:36 0 [Note] Server socket created on IP: '127.0.0.1', port
Mar 05 20:31:36 ubuntu-audit mariadb[1115]: 2026-03-05 20:31:36 0 [Note] /usr/sbin/mariadb: ready for connections.
Mar 05 20:31:36 ubuntu-audit mariadb[1115]: Version: '10.11.14-MariaDB-0ubuntu0.24.04.1' socket: '/run/mysqld/mysqld.
Mar 05 20:31:36 ubuntu-audit systemd[1]: Started mariadb.service - MariaDB 10.11.14 database server.
Mar 05 20:31:36 ubuntu-audit /etc/mysql/debian-start[1302]: Upgrading MariaDB tables if necessary.
Mar 05 20:31:36 ubuntu-audit /etc/mysql/debian-start[1313]: Checking for insecure root accounts.
Mar 05 20:31:36 ubuntu-audit /etc/mysql/debian-start[1317]: Triggering myisam-recover for all MyISAM tables and aria-re
lines 1-28/28 (END)
```

Rysunek 10: Status usługi MariaDB

Zestawienie wersji wszystkich zainstalowanych usług przedstawia poniższy zrzut ekranu, wykonany przy użyciu poleceń `apache2 -v`, `nginx -v` oraz `mysql -version`.

```
dawid@ubuntu-audit:~$ apache2 -v
Server version: Apache/2.4.58 (Ubuntu)
Server built: 2025-12-09T15:50:28
dawid@ubuntu-audit:~$ nginx -v
nginx version: nginx/1.24.0 (Ubuntu)
dawid@ubuntu-audit:~$ mysql --version
mysql Ver 15.1 Distrib 10.11.14-MariaDB, for debian-linux-gnu (x86_64) using EditLine wrapper
dawid@ubuntu-audit:~$
```

Rysunek 11: Wersje Apache, Nginx oraz MariaDB

6.1.4. Podsumowanie identyfikacji zasobów

Na podstawie przeprowadzonej identyfikacji zasobów sporządzono zestawienie wszystkich aktywnych usług sieciowych stanowiących powierzchnię ataku audytowanego systemu:

Port	Protokół	Usługa	Uwagi
22/TCP	SSH	OpenSSH 9.6p1	Dostępny z sieci, uwierzytelnianie hasłem włączone
80/TCP	HTTP	Nginx 1.24.0	Dostępny z sieci, domyślna strona serwera
3306/TCP	MySQL	MariaDB 10.11.14	Niedostępny z sieci (nasłuch na 127.0.0.1)

53/UDP	DNS	systemd-resolved	Lokalny resolver, niedostępny z sieci
--------	-----	------------------	---------------------------------------

Usługa FTP (vsftpd) została zainstalowana i skonfigurowana na późniejszym etapie audytu, w ramach symulacji podatności. W stanie początkowym systemu usługa FTP nie była aktywna.

6.2. Przygotowanie systemu audytującego

Przed przystąpieniem do właściwych testów na maszynie Kali Linux zainstalowano i skonfigurowano narzędzia audytowe niezbędne do przeprowadzenia rekonesansu oraz skanowania podatności. Kali Linux jest dystrybucją systemu GNU/Linux dedykowaną do testów penetracyjnych i audytów bezpieczeństwa, zawierającą w standardowej instalacji szeroki zestaw narzędzi audytowych. W ramach przygotowania środowiska doinstalowano brakujące komponenty oraz skonfigurowano platformę GVM/OpenVAS.

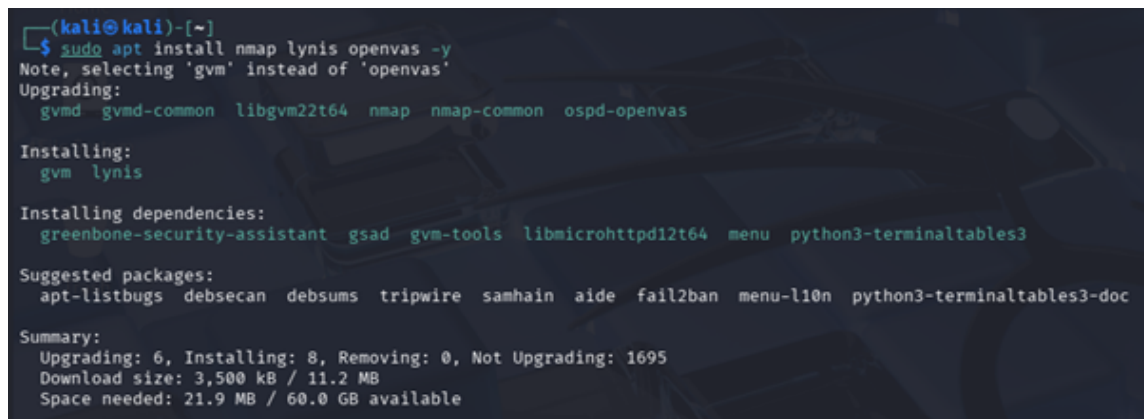
6.2.1. Instalacja narzędzi audytowych

Na maszynie Kali Linux zainstalowano pakiety niezbędne do przeprowadzenia audytu przy użyciu polecenia:

```
sudo apt install nmap lynis openvas -y
```

Polecenie zainstalowało lub zaktualizowało następujące komponenty:

- **Nmap** – narzędzie do skanowania sieci i identyfikacji usług,
- **Lynis** – narzędzie do lokalnego audytu konfiguracji systemu,
- **GVM** (Greenbone Vulnerability Manager) – platforma zarządzania skanowaniem podatności, będąca podstawą OpenVAS.



```
(kali@kali)-[~]
$ sudo apt install nmap lynis openvas -y
Note, selecting 'gvm' instead of 'openvas'
Upgrading:
  gvm  gvm-common  libgvm22t64  nmap  nmap-common  osdp-openvas

Installing:
  gvm  lynis

Installing dependencies:
  greenbone-security-assistant  gsad  gvm-tools  libmicrohttpd12t64  menu  python3-terminaltables3

Suggested packages:
  apt-listbugs  debsecan  debsums  tripwire  samhain  aide  fail2ban  menu-l10n  python3-terminaltables3-doc

Summary:
  Upgrading: 6, Installing: 8, Removing: 0, Not Upgrading: 1695
  Download size: 3,500 kB / 11.2 MB
  Space needed: 21.9 MB / 60.0 GB available
```

Rysunek 12: Instalacja narzędzi audytowych w systemie Kali Linux

6.2.2. Konfiguracja i inicjalizacja środowiska GVM/OpenVAS

Po zainstalowaniu pakietu GVM konieczna była jego inicjalizacja, obejmująca utworzenie bazy danych PostgreSQL, wygenerowanie certyfikatów TLS, konfigurację kont użytkowników oraz pobranie aktualnej bazy danych podatności NVT (Network Vulnerability Tests). Inicjalizację przeprowadzono przy użyciu skryptu:

```
sudo gvm-setup
```

Proces inicjalizacji obejmował następujące kroki wykonywane automatycznie przez skrypt:

- uruchomienie usługi PostgreSQL,
- utworzenie bazy danych GVM i użytkownika administracyjnego,
- wygenerowanie certyfikatów TLS dla interfejsu webowego,
- pobranie i synchronizację bazy danych NVT z serwerów Greenbone Community Feed,
- pobranie danych SCAP (Security Content Automation Protocol) oraz danych CERT.

Po zakończeniu inicjalizacji wygenerowane zostało hasło administratora, które wykorzystano do logowania w panelu webowym OpenVAS dostępnym pod adresem <https://127.0.0.1:9392>.



```
(kali@kali)-[~]
└─$ sudo gvm-setup
This script is provided and maintained by Debian and Kali.
If you find any issue in this script, please report it directly to Debian or Kali

[>] Starting PostgreSQL service
[>] Creating GVM's certificate files
[>] Creating PostgreSQL database
[*] Creating database user
[*] Creating database
[*] Creating permissions
CREATE ROLE
[*] Applying permissions
GRANT ROLE
[*] Creating extension uuid-osspl
CREATE EXTENSION
[*] Creating extension pgcrypto
CREATE EXTENSION
[*] Creating extension pg-gvm
CREATE EXTENSION
[>] Migrating database
[>] Checking for GVM admin user
: INFO:2026-03-05 20h51.45 utc:6804: Getting users.
[*] Creating user admin for gvm
: INFO:2026-03-05 20h51.46 utc:6816: Creating user.
[*] Please note the generated admin password
[*] User created with password 'f17fd6bf-6df3-43c3-8894-c2de01e1a33d'.
[*] Configure Feed Import Owner
[*] Define Feed Import Owner
: INFO:2026-03-05 20h51.46 utc:6825: Getting users.
[*] Update GVM feeds
Running as root. Switching to user '_gvm' and group '_gvm'.
Trying to acquire lock on /var/lib/openvas/feed-update.lock
Acquired lock on /var/lib/openvas/feed-update.lock
  Downloading Notus files from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/notus/ to /var/lib/notus
  Downloading NASL files from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/nasl/ to /var/lib/openvas/plugins
Releasing lock on /var/lib/openvas/feed-update.lock
Trying to acquire lock on /var/lib/gvm/feed-update.lock
Acquired lock on /var/lib/gvm/feed-update.lock
  Downloading SCAP data from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/scap-data/ to /var/lib/gvm/scap-data
```

Rysunek 13: Konfiguracja i inicjalizacja środowiska GVM/OpenVAS

6.2.3. Weryfikacja gotowości środowiska

Po zakończeniu konfiguracji zweryfikowano poprawność działania środowiska audytowego poprzez zalogowanie do panelu webowego OpenVAS oraz sprawdzenie statusu usług GVM. Poprawna inicjalizacja środowiska była warunkiem koniecznym do przeprowadzenia wia-rygodnych skanów podatności – niekompletna baza NVT mogłaby skutkować pominięciem istotnych podatności podczas skanowania.

Środowisko GVM/OpenVAS zostało uznane za gotowe do przeprowadzenia audytu po potwierdzeniu następujących warunków:

- poprawne zalogowanie do panelu webowego,
- brak błędów w statusie usług `gvmd`, `osspd-openvas` oraz `notus-scanner`,
- potwierdzenie aktualności bazy danych NVT.

6.3. Rekonesans usług przy użyciu Nmap

Rekonesans stanowił pierwszy aktywny etap audytu, podczas którego z poziomu maszyny Kali Linux przeprowadzono skanowanie audytowanego serwera Ubuntu w celu identyfikacji dostępnych usług sieciowych. Celem tego etapu było odwzorowanie perspektywy

potencjalnego atakującego przeprowadzającego wstępne rozpoznanie środowiska – bez posiadania wiedzy o wewnętrznej konfiguracji systemu.

6.3.1. Metodyka skanowania

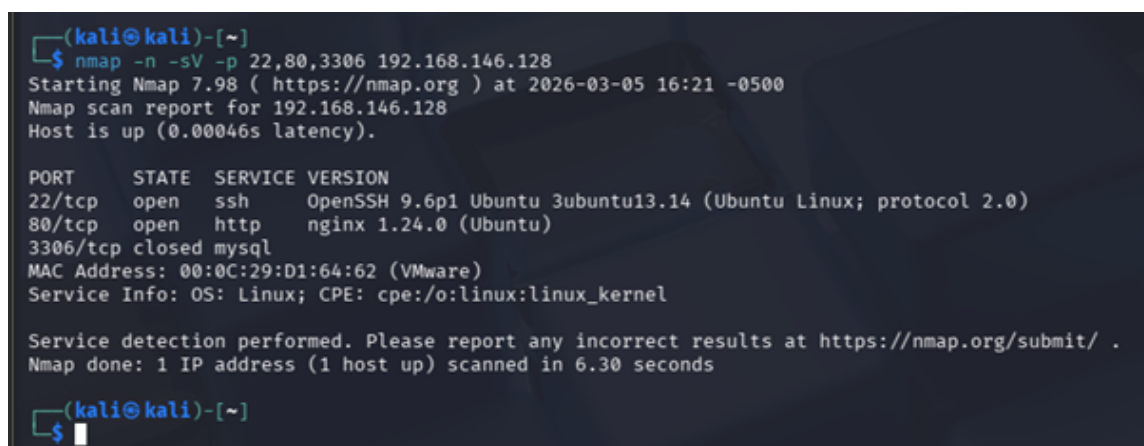
Skanowanie przeprowadzono przy użyciu narzędzia Nmap 7.98 z następującymi parametrami:

```
nmap -n -sV -p 22,80,3306 192.168.146.128
```

Zastosowane przełączniki miały następujące znaczenie:

- **-n** – wyłączenie rozwiązywania nazw DNS, co przyspiesza skanowanie i eliminuje zbędne zapytania DNS,
- **-sV** – wykrywanie wersji działających usług (Service Version Detection), pozwalające na identyfikację dokładnych wersji oprogramowania na otwartych portach,
- **-p 22,80,3306** – ograniczenie skanowania do portów będących przedmiotem audytu.

6.3.2. Wyniki skanowania



```
(kali㉿kali)-[~]
$ nmap -n -sV -p 22,80,3306 192.168.146.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-05 16:21 -0500
Nmap scan report for 192.168.146.128
Host is up (0.00046s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.24.0 (Ubuntu)
3306/tcp  closed mysql
MAC Address: 00:0C:29:D1:64:62 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.30 seconds

(kali㉿kali)-[~]
$
```

Rysunek 14: Skanowanie usług serwera Ubuntu przy użyciu Nmap

Skan został ukończony w czasie 6,30 sekundy. Nmap zidentyfikował host jako aktywny (latencja 0,00046s) oraz wykrył następujące usługi:

Port	Stan	Usługa i wersja
------	------	-----------------

22/TCP	otwarty	OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
80/TCP	otwarty	nginx 1.24.0 (Ubuntu)
3306/TCP	zamknięty	mysql

Nmap zidentyfikował również system operacyjny hosta na podstawie fingerprinta sieciowego: *OS: Linux; CPE: cpe:/o:linux:linux_kernel*, co potwierdziło, że audytowany host działa pod kontrolą systemu Linux. Adres MAC maszyny wirtualnej wynosił 00:0C:29:D1:64:62 (VMware).

6.3.3. Analiza wyników rekonesansu

Wyniki skanowania Nmap dostarczyły następujących informacji istotnych z punktu widzenia dalszego audytu:

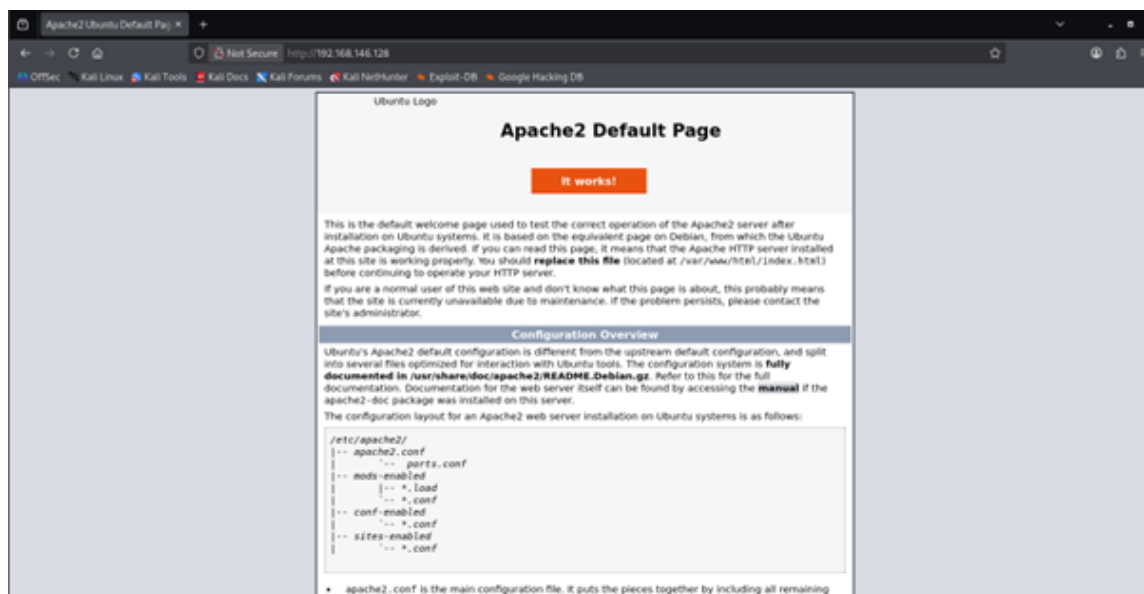
Port 22/TCP (SSH) – usługa OpenSSH w wersji 9.6p1 była dostępna z poziomu sieci. Wersja ta jest stosunkowo aktualna, jednak sam fakt dostępności usługi SSH z sieci przy włączonym uwierzytelnianiu hasłem stanowił potencjalny wektor ataku brute force. Dokładna wersja oprogramowania ujawniona przez serwer mogła zostać wykorzystana przez atakującego do wyszukania podatności charakterystycznych dla tej wersji.

Port 80/TCP (HTTP) – serwer Nginx 1.24.0 był dostępny z poziomu sieci i zwracał domyślną stronę serwera. Ujawnienie wersji serwera HTTP w nagłówkach odpowiedzi oraz w wyniku skanowania Nmap stanowi podatność informacyjną – atakujący uzyskuje wiedzę o dokładnej wersji oprogramowania, co ułatwia wyszukanie znanych podatności.

Port 3306/TCP (MariaDB) – port był widoczny jako zamknięty z perspektywy sieci, co oznaczało, że usługa MariaDB nasłuchiwała wyłącznie na interfejsie lokalnym (127.0.0.1). Była to poprawna konfiguracja eliminująca bezpośredni dostęp sieciowy do bazy danych.

6.3.4. Weryfikacja dostępności usługi HTTP

Dostępność serwera HTTP zweryfikowano dodatkowo z poziomu przeglądarki internetowej na maszynie Kali Linux, wpisując adres `http://192.168.146.128`. Serwer zwrócił domyślną stronę powitalną Nginx, potwierdzając poprawność działania usługi. Warto zaznaczyć, że wyświetlona strona zawierała informację o wersji serwera, co stanowi typową podatność informacyjną zalecaną do usunięcia w środowiskach produkcyjnych poprzez ustawienie dyrektywy `server_tokens off` w konfiguracji Nginx.



Rysunek 15: Weryfikacja działania serwera HTTP z poziomu przeglądarki

6.3.5. Wnioski z rekonesansu

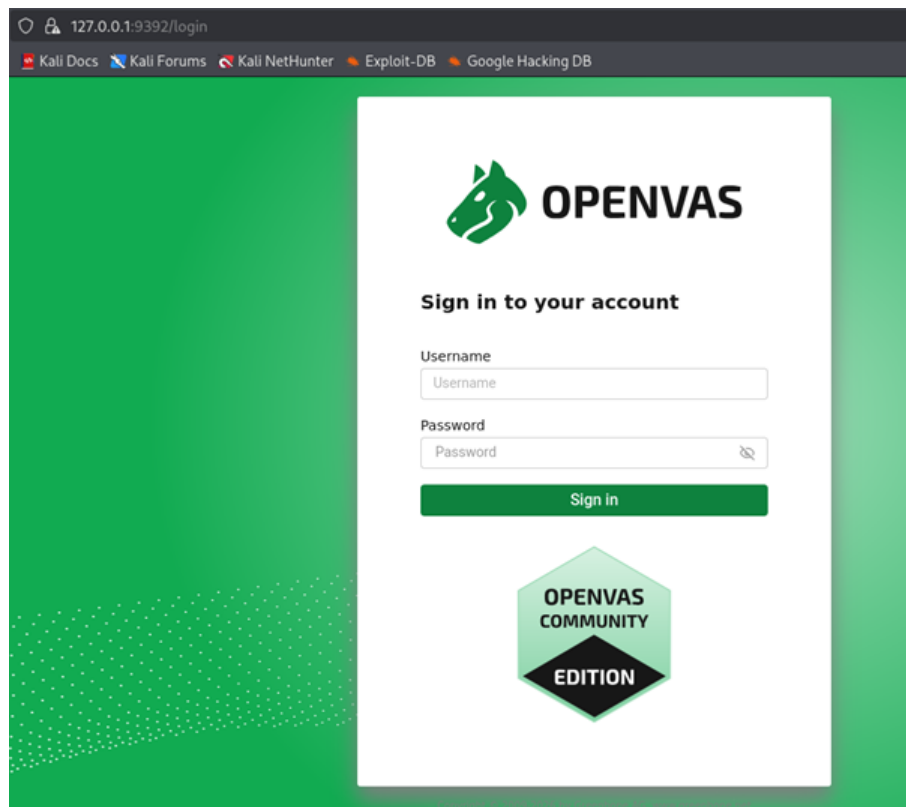
Na podstawie przeprowadzonego rekonesansu określono powierzchnię ataku audytowanego systemu przed przystąpieniem do skanowania podatności. Zidentyfikowano dwa potencjalne wektory ataku dostępne z poziomu sieci:

- usługa SSH na porcie 22/TCP jako potencjalny cel ataku brute force lub wykorzystania podatności w konkretnej wersji OpenSSH,
- usługa HTTP na porcie 80/TCP jako potencjalny cel ataków na aplikację webową lub wykorzystania podatności serwera Nginx.

Baza danych MariaDB nie była dostępna z poziomu sieci w stanie początkowym, co eliminowało ten komponent jako bezpośredni wektor ataku zewnętrznego. Wyniki rekonesansu posłużyły jako podstawa do skonfigurowania zadania skanowania w narzędziu OpenVAS.

6.4. Uruchomienie i konfiguracja OpenVAS

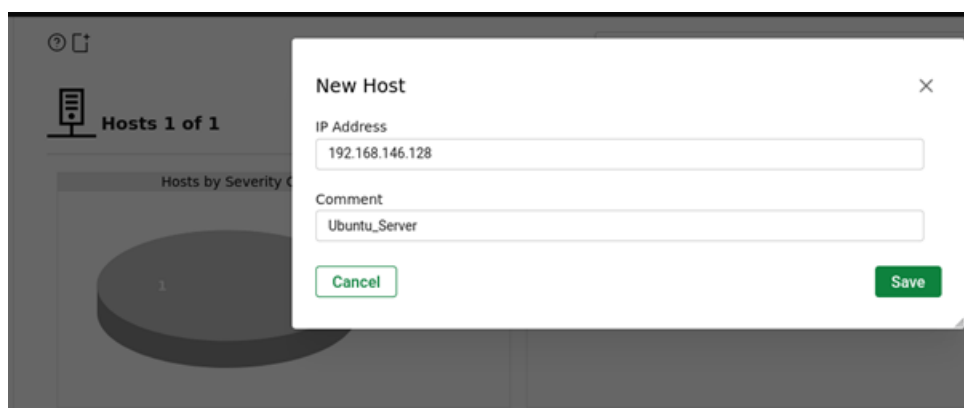
Po poprawnym przygotowaniu środowiska GVM wykonano logowanie do panelu webowego OpenVAS, dodano host audytowany jako cel skanowania oraz utworzono i uruchomiono zadanie skanowania. Panel OpenVAS dostępny był pod adresem <https://127.0.0.1:9392> na maszynie Kali Linux.



Rysunek 16: Panel logowania OpenVAS

6.4.1. Dodanie hosta audytowanego

W panelu OpenVAS dodano adres IP audytowanego serwera (192.168.146.128) jako cel skanowania z komentarzem *Ubuntu_Server*. Prawidłowe zdefiniowanie celu było warunkiem koniecznym do uruchomienia skanowania.

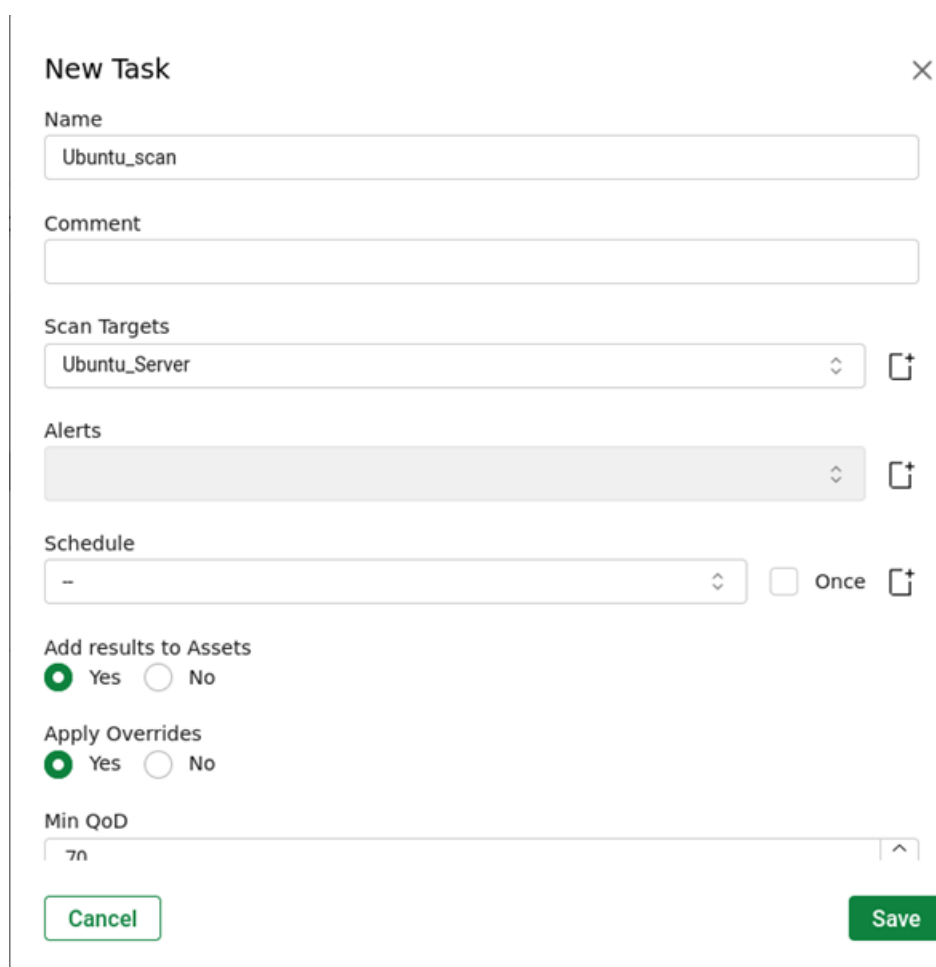


Rysunek 17: Dodanie hosta Ubuntu Server do OpenVAS

6.4.2. Konfiguracja zadania skanowania

Utworzono zadanie skanowania o nazwie *Ubuntu_scan* z następującymi parametrami:

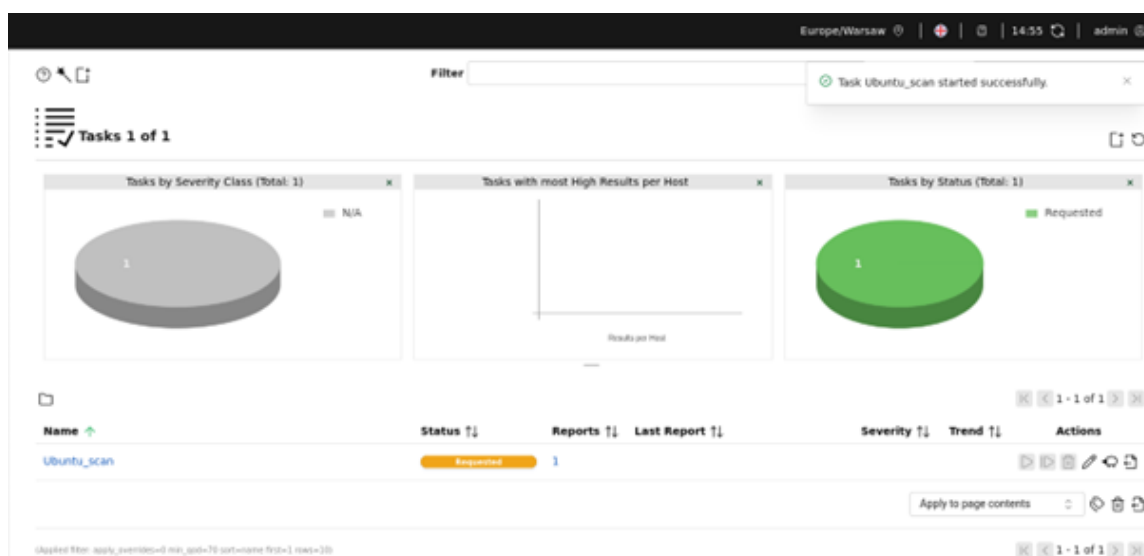
- **Scan Targets** – Ubuntu_Server (adres 192.168.146.128),
- **Min QoD** – 70%, co oznacza uwzględnienie wyłącznie wyników o jakości detekcji co najmniej 70%,
- **Apply Overrides** – tak, co pozwala na uwzględnienie nadpisań przy klasyfikacji podatności,
- **Add results to Assets** – tak, wyniki skanowania trafiają do bazy zasobów OpenVAS.



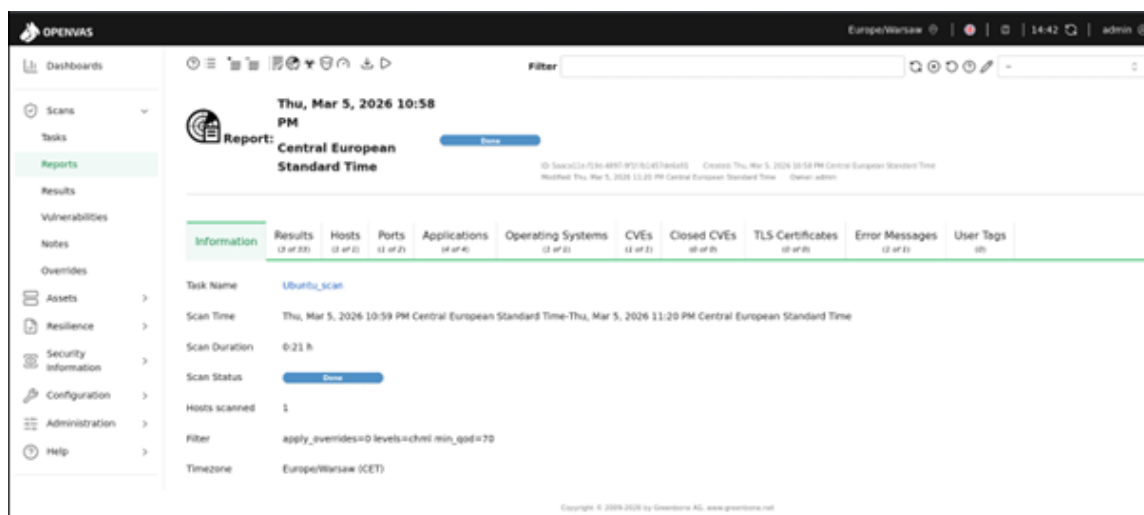
The image shows a 'New Task' configuration window in OpenVAS. It contains the following fields and options:

- Name:** A text input field containing 'Ubuntu_scan'.
- Comment:** An empty text input field.
- Scan Targets:** A dropdown menu showing 'Ubuntu_Server' with a plus icon to add more.
- Alerts:** A dropdown menu that is currently empty with a plus icon to add more.
- Schedule:** A dropdown menu showing '--' with a plus icon to add more, and a checkbox labeled 'Once' which is currently unchecked.
- Add results to Assets:** Radio buttons for 'Yes' (selected) and 'No'.
- Apply Overrides:** Radio buttons for 'Yes' (selected) and 'No'.
- Min QoD:** A text input field containing '70'.
- Buttons:** 'Cancel' and 'Save' buttons at the bottom.

Rysunek 18: Tworzenie zadania skanowania w OpenVAS



Rysunek 19: Uruchomienie zadania skanowania w OpenVAS



Rysunek 20: Raport z pierwszego skanowania podatności w OpenVAS

6.5. Stan początkowy systemu – audyt wyjściowy

Pierwsze skanowanie OpenVAS przeprowadzono na systemie w stanie wyjściowym, przed wprowadzeniem jakichkolwiek celowych słabości konfiguracyjnych. Celem tego skanu było ustalenie punktu odniesienia (baseline) poziomu bezpieczeństwa systemu oraz identyfikacja podatności wynikających z domyślnej konfiguracji zainstalowanych usług.

Skan trwał 0:21 godziny i został zakończony ze statusem *Done*. Wystąpił jeden timeout testu NVT (*NVT timed out after 320 seconds*) dla skanu MAC Nmap na porcie ogólnym TCP, co nie wpłynęło na wiarygodność wyników.

Name ↑	Status ↑	Reports ↑	Last Report ↑	Severity ↑	Trend ↑	Actions
Przed audytem	Done	1	Sat, Apr 18, 2026 7:22 PM Central European Summer Time	2.6 (Low)		   

Rysunek 21: Audyt początkowy – komunikat o timeout jednego z testów

Information	Results (3 of 35)	Hosts (2 of 3)	Ports (11 of 3)	Applications (5 of 3)	Operating Systems (2 of 3)	CVEs (11 of 2)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (2 of 3)	User Tags (0)
Task Name	Przed audytem									
Scan Time	Sat, Apr 18, 2026 7:22 PM Central European Summer Time-Sat, Apr 18, 2026 7:42 PM Central European Summer Time									
Scan Duration	0:20 h									
Scan Status	Done									
Hosts scanned	1									
Filter	apply_overrides=0 levels=chml min_qod=70									
Timezone	Europe/Warsaw (CEST)									

Rysunek 22: Audyt początkowy – podsumowanie zadania

Information	Results (3 of 35)	Hosts (2 of 3)	Ports (11 of 3)	Applications (5 of 3)	Operating Systems (2 of 3)	CVEs (11 of 2)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (2 of 3)	User Tags (0)
Vulnerability ↑										
Severity ↓										
QoD ↑										
Host IP ↑										
Name ↑										
Location ↑										
EPSS Score ↑										
Percentile ↑										
Created ↑										
TCP Timestamps Information Disclosure										
Weak MAC Algorithm(s) Supported (SSH)										
ICMP Timestamp Reply information Disclosure										
Applied filter: apply_overrides=0 levels=chml max_qod=100 min_qod=70 find=1 sort=reverse=severity										

Rysunek 23: Audyt początkowy – zakładka Information

Information	Results (3 of 35)	Hosts (2 of 3)	Ports (11 of 3)	Applications (5 of 3)	Operating Systems (2 of 3)	CVEs (11 of 2)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (2 of 3)	User Tags (0)
IP Address ↑										
Hostname ↑										
OS ↑										
Ports ↑										
Apps ↑										
Distance ↑										
Auth										
Start ↑										
End ↑										
Critical ↑										
High ↑										
Medium ↑										
Low ↑										
Info ↑										
192.168.146.128										
Sat, Apr 18, 2026 7:22 PM Central European Summer Time										
Sat, Apr 18, 2026 7:42 PM Central European Summer Time										
0										
0										
0										
3										
0										

Rysunek 24: Audyt początkowy – wykryte podatności

Information	Results (3 of 35)	Hosts (1 of 2)	Ports (1 of 3)	Applications (5 of 5)	Operating Systems (1 of 2)	CVEs (1 of 2)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (1 of 2)	User Tags (0)
Port		Hosts		Severity						
22/tcp		1		3.4 (Low)						

Applied filter: apply_exclude=0 levels=chrt rows=100 max_gid=70 first=1 sort-reverse=severity

Rysunek 25: Audyt początkowy – host i klasy ryzyka

Information	Results (3 of 35)	Hosts (1 of 2)	Ports (2 of 3)	Applications (5 of 5)	Operating Systems (1 of 2)	CVEs (1 of 2)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (1 of 2)	User Tags (0)
Application CPE		Hosts		Occurrences		Severity				
cpe:/a:mariadb:mariadb		1		1		N/A				
cpe:/a:nginx:nginx:1.24.0		1		1		N/A				
cpe:/a:ietf:secure_shell_protocol:2.0		1		1		N/A				
cpe:/a:nginx:nginx:1.24.0		1		1		N/A				
cpe:/a:openbsd:openssh:9.6p1		1		1		N/A				

Rysunek 26: Audyt początkowy – wykryte porty

Information	Results (3 of 35)	Hosts (2 of 2)	Ports (2 of 3)	Applications (5 of 5)	Operating Systems (2 of 2)	CVEs (1 of 2)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (1 of 2)	User Tags (0)
Error Message		Host		Hostname		NVT		Port		
NVT timed out after 320 seconds.		192.168.146.128		Nmap MAC Scan		general/tcp				

Applied filter: apply_exclude=0 levels=chrt rows=100 max_gid=70 first=1 sort-reverse=severity

Rysunek 27: Audyt początkowy – wykryte aplikacje

Pierwsze skanowanie wykazało **brak podatności krytycznych, wysokich oraz średnich**. Oznacza to, że system w stanie początkowym był skonfigurowany względnie poprawnie. Jedynym aktywnym portem widocznym z sieci był port 22/TCP (SSH). OpenVAS zidentyfikował trzy podatności niskiego poziomu ryzyka, które omówiono szczegółowo w dalszej części raportu:

- TCP Timestamps Information Disclosure (CVSS 2.6),
- Weak MAC Algorithms Supported – SSH (CVSS 2.6),
- ICMP Timestamp Reply Information Disclosure (CVSS 2.1).

Wyniki pierwszego skanu posłużyły jako punkt odniesienia do oceny skuteczności późniejszych działań – zarówno symulacji podatności, jak i hardeningu systemu.

6.6. Symulacja podatności

W celu uzyskania bardziej realistycznego i reprezentatywnego scenariusza audytu celowo wprowadzono słabości konfiguracyjne do wybranych usług systemu. Działanie to było zgodne z przyjętą metodologią audytu white-box i miało na celu praktyczne wykazanie, jak błędna konfiguracja usług sieciowych wpływa na poziom bezpieczeństwa systemu oraz czy narzędzia audytowe są w stanie skutecznie wykryć wprowadzone podatności.

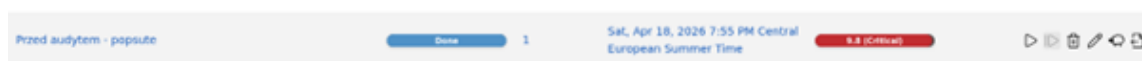
6.6.1. Zakres wprowadzonych zmian

W ramach symulacji podatności wprowadzono następujące zmiany konfiguracyjne:

- **Oslabienie konfiguracji SSH** – zmieniono konfigurację usługi OpenSSH w pliku `/etc/ssh/sshd_config` w sposób dopuszczający logowanie przy użyciu słabego hasła oraz umożliwiający logowanie konta `root`. Ustawiono proste, łatwe do odgadnięcia hasło użytkownika, co symulowało typowy błąd administratora systemu.
- **Uruchomienie podatnej konfiguracji FTP** – zainstalowano i uruchomiono serwer vsftpd 3.0.5 z włączonym dostępem anonimowym (`anonymous_enable=YES`) oraz bez szyfrowania transmisji. Port 21/TCP stał się dostępny z poziomu sieci laboratoryjnej.

6.6.2. Wyniki skanu po symulacji podatności

Po wprowadzeniu zmian przeprowadzono ponowne skanowanie OpenVAS z tą samą konfiguracją zadania co w audycie wyjściowym. Skan trwał 0:21 godziny.



Rysunek 28: Skan systemu po celowym osłabieniu konfiguracji – podsumowanie zadania

Information	Results (8 of 42)	Hosts (2 of 1)	Ports (2 of 4)	Applications (6 of 6)	Operating Systems (2 of 1)	CVEs (3 of 3)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (1 of 1)	User Tags (0)
Task Name	Przed audytem - popsute									
Scan Time	Sat, Apr 18, 2026 7:55 PM Central European Summer Time-Sat, Apr 18, 2026 8:16 PM Central European Summer Time									
Scan Duration	0:21 h									
Scan Status	Done									
Hosts scanned	1									
Filter	apply_overrides=0 levels=chml_min_qod=70									
Timezone	Europe/Warsaw (CEST)									

Rysunek 29: Skan systemu po osłabieniu konfiguracji – zakładka Information

SSH Brute Force Logins With Default Credentials Reporting		95 %	192.168.146.128	22/tcp	N/A	N/A	Central European Summer Time
Anonymous FTP Login Reporting		80 %	192.168.146.128	21/tcp	N/A	N/A	Sat, Apr 18, 2026 8:02 PM Central European Summer Time
FTP Unencrypted Cleartext Login		70 %	192.168.146.128	21/tcp	N/A	N/A	Sat, Apr 18, 2026 8:02 PM Central European Summer Time
TCP Timestamps Information Disclosure		80 %	192.168.146.128	general/tcp	N/A	N/A	Sat, Apr 18, 2026 8:02 PM Central European Summer Time
Weak MAC Algorithm(s) Supported (SSH)		80 %	192.168.146.128	22/tcp	N/A	N/A	Sat, Apr 18, 2026 8:02 PM Central European Summer Time
ICMP Timestamp Reply Information Disclosure		80 %	192.168.146.128	general/icmp	N/A	N/A	Sat, Apr 18, 2026 8:02 PM Central European

Rysunek 30: Skan systemu po osłabieniu konfiguracji – lista podatności

Information	Results (8 of 42)	Hosts (1 of 1)	Ports (2 of 4)	Applications (6 of 6)	Operating Systems (2 of 1)	CVEs (3 of 2)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (2 of 1)	User Tags (0)			
1 - 1 of 1													
IP Address	Hostname	OS	Ports	Apps	Distance	Auth	Start	End	Critical	High	Medium	Low	Info
192.168.146.128			2	6			Sat, Apr 18, 2026 7:55 PM	Sat, Apr 18, 2026 8:16 PM	1	0	2	3	0
						Central European Summer Time	Central European Summer Time						

Applied filter: apply_overrides=0 levels=chrd rows=100 min_gpb=70 first=1 sort.reverse=severity

1 - 1 of 1

Rysunek 31: Skan systemu po osłabieniu konfiguracji – host i klasy ryzyka

Port	Hosts	Severity
22/tcp	1	
21/tcp	1	

Applied filter: apply_overrides=0 levels=chrd rows=100 min_gpb=70 first=1 sort.reverse=severity

Rysunek 32: Skan systemu po osłabieniu konfiguracji – wykryte porty

Information	Results (6 of 42)	Hosts (2 of 3)	Ports (2 of 4)	Applications (6 of 6)	Operating Systems (2 of 3)	CVEs (3 of 3)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (1 of 1)	User Tags (0)
Application CPE ↑↓										
		Hosts ↑↓		Occurrences ↑↓		Severity ↓				
	cpe:/a:nginx:nginx:1.24.0	1		1		N/A				
	cpe:/a:nginx:nginx:1.24.0	1		1		N/A				
	cpe:/a:vsftpd_project:vsftpd:3.0.5	1		1		N/A				
	cpe:/a:mariadb:mariadb	1		1		N/A				
	cpe:/a:openbsd:openssh:9.6p1	1		1		N/A				
	cpe:/a:ietf:secure_shell_protocol:2.0	1		1		N/A				

(Applied filter: apply_overrides=0 levels=chrt rows=100 min_gad=70 first=1 sort-reverse=severity)

Rysunek 33: Skan systemu po osłabieniu konfiguracji – wykryte aplikacje

Information	Results (6 of 42)	Hosts (2 of 3)	Ports (2 of 4)	Applications (6 of 6)	Operating Systems (2 of 3)	CVEs (3 of 3)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (1 of 1)	User Tags (0)
CVE ↑↓										
		NVT ↑↓		Hosts ↑↓		Occurrences ↑↓		Severity ↓		
	CVE-1999-0501 CVE-1999-0502 CVE-1999-0507 CVE-1999-0508 CVE-2005-1379 CVE-2006-5288 CVE-2009-3710 CVE-2012-4577 CVE-2016-1000245 CVE-2017-16523 CVE-2017-20214 CVE-2018-25138 CVE-2018-25147 CVE-2019-25241 CVE-2019-25291 CVE-2020-29583 CVE-2020-36915 CVE-2020-37092 CVE-2020-9473 CVE-2021-27797 CVE-2021-47744 CVE-2023-1944 CVE-2023-53983 CVE-2024-22902 CVE-2024-31970 CVE-2024-46328 CVE-2025-12592 CVE-2025-41696 CVE-2025-68718			1		1		9.8 (Critical)		
	CVE-1999-0497	Anonymous FTP Login Reporting		1		1		4.8 (Medium)		
	CVE-1999-0524	ICMP Timestamp Reply Information Disclosure		1		1		2.1 (Low)		

(Applied filter: apply_overrides=0 levels=chrt rows=100 min_gad=70 first=1 sort-reverse=severity)

Rysunek 34: Skan systemu po osłabieniu konfiguracji – powiązane CVE

Information	Results (6 of 42)	Hosts (2 of 3)	Ports (2 of 4)	Applications (6 of 6)	Operating Systems (2 of 3)	CVEs (3 of 3)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (1 of 1)	User Tags (0)										
1 - 1 of 1 <table><thead><tr><th>Error Message </th><th>Host </th><th>Hostname </th><th>NVT </th><th>Port </th></tr></thead><tbody><tr><td>NVT timed out after 320 seconds.</td><td>192.168.146.128</td><td></td><td>Nmap MAC Scan</td><td>general/tcp</td></tr></tbody></table> (Applied filter: apply_overrides=0 levels=chrt rows=100 min_gad=70 first=1 sort-reverse=severity) 1 - 1 of 1											Error Message	Host	Hostname	NVT	Port	NVT timed out after 320 seconds.	192.168.146.128		Nmap MAC Scan	general/tcp
Error Message	Host	Hostname	NVT	Port																
NVT timed out after 320 seconds.	192.168.146.128		Nmap MAC Scan	general/tcp																

Rysunek 35: Skan systemu po osłabieniu konfiguracji – komunikat o timeout

Po wprowadzeniu zmian konfiguracyjnych OpenVAS wykrył znacząco więcej podatności niż w stanie wyjściowym. Wyniki skanu wykazały:

- 1 podatność krytyczną (CVSS 9.8) – związaną z usługą SSH,
- 2 podatności średnie (CVSS 4.8–6.4) – związane z usługą FTP,
- 3 podatności niskie (CVSS 2.1–2.6) – tożsame z wykrytymi w stanie wyjściowym.

Wynik ten potwierdził, że narzędzie OpenVAS poprawnie wykryło wszystkie celowo wprowadzone słabości konfiguracyjne. Szczegółowy opis każdej z wykrytych podatności przedstawiono w kolejnych podrozdziałach.

6.7. SSH Brute Force Logins With Default Credentials

Identyfikator: podatność wykryta przez OpenVAS, powiązana z CVE-1999-0501, CVE-1999-0502, CVE-2016-10009 oraz wieloma innymi CVE dotyczącymi słabego uwierzytelnienia w usłudze SSH

Poziom ryzyka: Critical

CVSS: 9.8

Lokalizacja: port 22/TCP

Opis techniczny:

Podatność polegała na umożliwieniu logowania do usługi SSH przy użyciu słabego, łatwego do odgadnięcia hasła oraz dopuszczeniu logowania konta uprzywilejowanego `root`. Usługa OpenSSH 9.6p1 była skonfigurowana z włączonym uwierzytelnianiem hasłem (`PasswordAuthentication yes`) bez jakichkolwiek mechanizmów ograniczających liczbę prób logowania po stronie samej usługi. Taka konfiguracja umożliwia przeprowadzenie skutecznego ataku słownikowego lub brute force, w którym atakujący systematycznie próbuje kolejnych kombinacji haseł aż do uzyskania dostępu.

OpenVAS przeprowadził test aktywny – podjął próby logowania przy użyciu listy domyślnych i typowych poświadczeń (tzw. default credentials), które zakończyły się sukcesem, co jednoznacznie potwierdziło podatność.

Proof of Concept (dowód):

Dowodem wystąpienia podatności był wynik OpenVAS wskazujący *SSH Brute Force Logins With Default Credentials Reporting* jako podatność krytyczną wykrytą na porcie 22/TCP hosta 192.168.146.128. OpenVAS skutecznie zalogował się do systemu przy użyciu domyślnych poświadczeń, co potwierdza realność zagrożenia – nie jest to wyłącznie podatność teoretyczna, lecz aktywnie wykorzystywalna luka.

Scenariusz ataku:

Atakujący posiadający dostęp sieciowy do portu 22/TCP mógłby przeprowadzić następującą sekwencję działań:

1. rozpoznanie usługi SSH przy użyciu Nmap i identyfikacja wersji OpenSSH,
2. uruchomienie narzędzia do ataków brute force (np. Hydra, Medusa) z listą typowych haseł,

3. uzyskanie dostępu do powłoki systemowej z uprawnieniami użytkownika lub roota,
4. instalacja backdoora lub eksfiltracja danych.

Wpływ biznesowy:

Skuteczne wykorzystanie tej podatności mogłoby doprowadzić do nieautoryzowanego dostępu administracyjnego do systemu, utraty poufności danych przechowywanych na serwerze, modyfikacji konfiguracji usług sieciowych, instalacji złośliwego oprogramowania oraz całkowitego przejęcia kontroli nad serwerem. W środowisku produkcyjnym skutki mogłyby obejmować wyciek danych osobowych klientów, naruszenie przepisów RODO oraz poważne straty wizerunkowe i finansowe organizacji.

Rekomendacja naprawy:

Należy wyłączyć logowanie hasłem przez SSH poprzez ustawienie `PasswordAuthentication no` w pliku `/etc/ssh/sshd_config` i przejście wyłącznie na uwierzytelnianie kluczem publicznym. Dodatkowo należy zablokować logowanie konta `root` (`PermitRootLogin no`), wprowadzić silne hasła dla wszystkich kont systemowych oraz wdrożyć mechanizm ochrony przed brute force w postaci narzędzia Fail2ban.

6.8. Anonymous FTP Login

Identyfikator: CVE-1999-0497

Poziom ryzyka: Medium

CVSS: 6.4

Lokalizacja: port 21/TCP

Opis techniczny:

Podatność polegała na dopuszczeniu anonimowego logowania do usługi FTP (vsftpd 3.0.5). Serwer FTP skonfigurowany z opcją `anonymous_enable=YES` pozwala każdemu użytkownikowi sieci na połączenie się z serwerem bez konieczności podawania prawidłowych danych uwierzytelniających – jako nazwę użytkownika wystarczy podać `anonymous` lub `ftp`, a hasłem może być dowolny ciąg znaków lub pusty ciąg. Jest to konfiguracja historycznie stosowana w publicznych serwerach FTP, jednak w środowiskach serwerowych stanowi poważne zagrożenie bezpieczeństwa.

Proof of Concept (dowód):

OpenVAS wykazał obecność podatności *Anonymous FTP Login Reporting* na porcie 21/TCP hosta 192.168.146.128. Narzędzie skutecznie zalogowało się do serwera FTP jako użytkownik anonimowy, potwierdzając realność zagrożenia.

Scenariusz ataku:

Atakujący mógłby połączyć się z serwerem FTP bez znajomości jakichkolwiek poświadczeń, odczytać listę dostępnych katalogów i plików, pobrać pliki do których anonimowy użytkownik ma dostęp, a w przypadku skonfigurowania katalogu z prawem zapisu – wgrać złośliwe pliki na serwer.

Wpływ biznesowy:

Nieautoryzowany użytkownik może uzyskać dostęp do zasobów serwera FTP bez konieczności posiadania poświadczeń, co może prowadzić do ujawnienia poufnych danych, nieautoryzowanego pobierania plików lub wgrania złośliwego oprogramowania. W środowisku produkcyjnym dostęp anonimowy może stanowić punkt wejścia do dalszej eskalacji uprawnień.

Rekomendacja naprawy:

Należy wyłączyć anonimowy dostęp do FTP poprzez ustawienie `anonymous_enable=NO` w pliku `/etc/vsftpd.conf`. Jeśli usługa FTP nie jest niezbędna, należy ją całkowicie wyłączyć i zablokować port 21/TCP w zaporze UFW. W przypadku konieczności utrzymania usługi transferu plików zaleca się zastąpienie FTP protokołem SFTP wbudowanym w OpenSSH.

6.9. FTP Unencrypted Cleartext Login

Identyfikator: podatność konfiguracyjna wykryta przez OpenVAS

Poziom ryzyka: Medium

CVSS: 4.8

Lokalizacja: port 21/TCP

Opis techniczny:

Protokół FTP w swojej podstawowej formie przesyła wszystkie dane, w tym dane uwierzytelniające (nazwa użytkownika i hasło), w postaci niezaszyfrowanego tekstu jawnego (cleartext). Oznacza to, że atakujący posiadający dostęp do ruchu sieciowego między klientem a serwerem FTP – przykładowo poprzez atak Man-in-the-Middle lub podsłuch segmentu sieci – może bez trudu przechwycić kompletne poświadczenia użytkownika. Podatność ta jest nieodłączną cechą protokołu FTP i nie wynika z błędu konfiguracji serwera, lecz z fundamentalnego braku mechanizmów szyfrowania w tym protokole.

Proof of Concept (dowód):

Wynik OpenVAS wskazał *FTP Unencrypted Cleartext Login* jako podatność średniego poziomu ryzyka na porcie 21/TCP. Narzędzie potwierdziło, że serwer vsftpd 3.0.5 akceptuje połączenia bez szyfrowania i przesyła dane logowania w postaci jawnej.

Scenariusz ataku:

Atakujący posiadający dostęp do segmentu sieci mógłby uruchomić narzędzie do przechwytywania pakietów (np. Wireshark, tcpdump), poczekać na połączenie użytkownika z serwerem FTP i odczytać przesyłane w jawnej postaci poświadczenia, a następnie wykorzystać je do logowania do innych usług (credential stuffing).

Wpływ biznesowy:

Przechwycenie danych uwierzytelniających FTP może prowadzić do nieautoryzowanego dostępu do zasobów serwera. W przypadku stosowania tych samych haseł w różnych usługach (password reuse) skompromitowanie hasła FTP może umożliwić dostęp do innych systemów organizacji, w tym poczty elektronicznej, VPN czy systemów administracyjnych.

Rekomendacja naprawy:

Należy zastąpić protokół FTP bezpieczniejszymi alternatywami: SFTP (SSH File Transfer Protocol) wbudowanym w OpenSSH lub FTPS (FTP over TLS). Jeśli transfer plików nie jest wymagany, usługę FTP należy całkowicie wyłączyć.

6.10. Podatności niskiego poziomu ryzyka

Identyfikatory: CVE-1999-0524 (ICMP Timestamp) oraz podatności informacyjne wykryte przez OpenVAS

Poziom ryzyka: Low

CVSS: 2.1–2.6

Opis techniczny:

W trakcie audytu – zarówno w stanie wyjściowym, jak i po symulacji podatności – OpenVAS konsekwentnie wykrywał trzy podatności niskiego poziomu ryzyka. Mają one charakter informacyjny i nie umożliwiają bezpośredniego przejęcia systemu, jednak mogą wspierać proces rozpoznania środowiska przez atakującego.

TCP Timestamps Information Disclosure (CVSS 2.6) – protokół TCP pozwala na dołączanie znaczników czasu (timestamps) do pakietów sieciowych w celu optymalizacji transmisji. Analiza tych znaczników przez atakującego może ujawnić informacje o czasie działania systemu (uptime) oraz ułatwić identyfikację systemu operacyjnego. Podatność jest obecna na wszystkich portach TCP systemu.

Weak MAC Algorithms Supported – SSH (CVSS 2.6) – usługa OpenSSH 9.6p1 obsługiwała algorytmy MAC (Message Authentication Code) uznawane za słabe z kryptograficznego punktu widzenia, w tym algorytmy oparte na funkcji skrótu MD5 (`hmac-md5`, `hmac-md5-96`) oraz SHA-1 (`hmac-sha1`, `hmac-sha1-96`). Choć podatność ta wymaga ak-

tywnego ataku kryptograficznego i nie jest trywialna w eksploatacji, stanowi odejście od aktualnych rekomendacji bezpieczeństwa dla protokołu SSH.

ICMP Timestamp Reply Information Disclosure (CVSS 2.1) – system odpowiadał na zapytania ICMP Timestamp Request, ujawniając informacje o bieżącym czasie systemowym. Podatność powiązana z CVE-1999-0524 może być wykorzystana do dokładniejszej identyfikacji systemu operacyjnego oraz synchronizacji czasu przez atakującego, co ułatwia planowanie ataków opartych na czasie.

Proof of Concept (dowód):

Wszystkie trzy podatności zostały wykryte przez OpenVAS w stanie wyjściowym systemu. Po wdrożeniu hardeningu podatność ICMP Timestamp Reply Information Disclosure została usunięta poprzez konfigurację zapory UFW blokującej odpowiedzi ICMP. Podatności TCP Timestamps oraz Weak MAC Algorithms pozostały w systemie jako podatności rezydualne niskiego ryzyka.

Wpływ biznesowy:

Podatności te nie umożliwiają bezpośredniego przejęcia systemu ani uzyskania nieautoryzowanego dostępu. Stanowią jednak źródło informacji dla atakującego przeprowadzającego rozpoznanie środowiska, mogą ułatwiać identyfikację systemu operacyjnego i jego wersji oraz wspierać planowanie bardziej zaawansowanych ataków.

Rekomendacja naprawy:

Należy rozważyć wyłączenie obsługi znaczników czasu TCP poprzez ustawienie parametru jądra `net.ipv4.tcp_timestamps=0` w pliku `/etc/sysctl.conf`. W konfiguracji SSH należy ograniczyć listę akceptowanych algorytmów MAC wyłącznie do bezpiecznych wariantów opartych na SHA-256 i SHA-512, dodając do pliku `/etc/ssh/sshd_config` dyrektywę `MACs hmac-sha2-256,hmac-sha2-512`.

7. Tabela podatności (Vulnerability Summary)

Poniższa tabela stanowi zbiorcze zestawienie wszystkich podatności wykrytych podczas audytu systemu Ubuntu Server. Zawiera identyfikatory, poziomy ryzyka zgodne z metryką CVSS v3.1 oraz aktualny status każdej podatności po przeprowadzeniu hardeningu.

ID	Podatność	Ryzyko	CVSS	Lokalizacja	Status
1	SSH Brute Force Logins With Default Credentials	Critical	9.8	port 22/TCP	Naprawiona

2	Anonymous FTP Login	Medium	6.4	port 21/TCP	Naprawiona
3	FTP Unencrypted Cleartext Login	Medium	4.8	port 21/TCP	Naprawiona
4	TCP Timestamps Information Disclosure	Low	2.6	wszystkie porty TCP	Pozostała
5	Weak MAC Algorithms Supported (SSH)	Low	2.6	port 22/TCP	Pozostała
6	ICMP Timestamp Reply Information Disclosure	Low	2.1	ICMP	Naprawiona

Spośród sześciu wykrytych podatności cztery zostały całkowicie usunięte w wyniku wdrożonych działań hardeningowych. Dwie podatności niskiego poziomu ryzyka (TCP Timestamps oraz Weak MAC Algorithms) pozostały w systemie – nie stanowią bezpośredniego zagrożenia, jednak mogą zostać usunięte w ramach dalszego hardeningu.

8. Analiza ryzyka

Analiza ryzyka została przeprowadzona dla wszystkich wykrytych podatności z uwzględnieniem dwóch głównych czynników: prawdopodobieństwa wykorzystania podatności przez atakującego oraz potencjalnego skutku dla bezpieczeństwa systemu i ciągłości działania usług. Wynikowy poziom ryzyka stanowi iloczyn tych dwóch wymiarów i wyznacza priority działań naprawczych.

Zagrożenie	Prawdopodobieństwo	Skutek	Ryzyko
Przejęcie dostępu przez SSH brute force	Wysokie	Wysoki	Wysokie
Anonimowy dostęp do FTP	Średnie	Średni	Średnie
Przechwycenie danych logowania FTP	Średnie	Średni	Średnie
Ujawnianie informacji diagnostycznych TCP/ICMP	Niskie	Niski	Niskie
Słabe algorytmy MAC w SSH	Niskie	Niski	Niskie

8.1. Omówienie wyników analizy ryzyka

Ryzyko wysokie – SSH Brute Force. Podatność związana z usługą SSH stanowiła największe zagrożenie dla badanego środowiska. Prawdopodobieństwo jej wykorzystania oceniono jako wysokie z kilku powodów: usługa była dostępna z poziomu sieci, uwierzytelnianie hasłem było włączone, a zastosowane hasło było słabe i podatne na atak słownikowy. Narzędzia automatyzujące ataki brute force na SSH (Hydra, Medusa) są powszechnie dostępne i nie wymagają zaawansowanej wiedzy technicznej. Skutek wykorzystania podatności oceniono jako wysoki – udany atak brute force prowadzi do pełnego przejęcia systemu z uprawnieniami zalogowanego użytkownika, a w przypadku włączonego logowania roota – do natychmiastowego uzyskania uprawnień administracyjnych.

Ryzyko średnie – podatności FTP. Obie podatności związane z usługą FTP (anonimowy dostęp oraz brak szyfrowania) oceniono jako ryzyko średnie. Anonimowy dostęp do FTP wymaga jedynie znajomości adresu serwera i dostępu sieciowego, natomiast przechwycenie niezaszyfrowanych poświadczeń FTP wymaga dostępu do segmentu sieci lub pozycji Man-in-the-Middle. Skutki obu podatności są ograniczone w porównaniu do podatności SSH – dotyczą przede wszystkim zasobów dostępnych przez FTP, jednak mogą stanowić punkt wejścia do dalszej eskalacji działań w środowisku.

Ryzyko niskie – podatności informacyjne. Podatności TCP Timestamps, Weak MAC Algorithms oraz ICMP Timestamp Reply mają charakter głównie informacyjny. Ich bezpośrednie wykorzystanie wymaga zaawansowanej wiedzy kryptograficznej lub dostępu do segmentu sieci. Nie umożliwiają samodzielnego przejęcia systemu, jednak wspierają proces rozpoznania środowiska i mogą ułatwić przeprowadzenie bardziej zaawansowanych ataków. Prawdopodobieństwo ich aktywnego wykorzystania w środowisku laboratoryjnym oceniono jako niskie.

9. Rekomendacje bezpieczeństwa

Na podstawie wyników audytu oraz przeprowadzonej analizy ryzyka opracowano zestaw rekomendacji bezpieczeństwa podzielonych na trzy kategorie czasowe. Kryterium podziału stanowiła krytyczność podatności oraz złożoność wdrożenia danego zabezpieczenia. Rekomendacje krótkoterminowe adresują podatności krytyczne i średnie wymagające natychmiastowej reakcji, średnioterminowe dotyczą wzmocnienia istniejących mechanizmów ochronnych, natomiast długoterminowe odnoszą się do budowania trwałej kultury bezpieczeństwa w organizacji.

Krótkoterminowe (do 24–72 godzin)

Działania z tej grupy powinny zostać wdrożone niezwłocznie, ponieważ adresują podatności umożliwiające przejęcie systemu lub nieautoryzowany dostęp do danych:

- **Wyłączenie logowania hasłem przez SSH** – ustawienie `PasswordAuthentication` no w pliku `/etc/ssh/sshd_config` i przejście wyłącznie na uwierzytelnianie kluczem publicznym. Jest to najskuteczniejsza metoda eliminacji ryzyka ataków brute force na usługę SSH.
- **Zablokowanie logowania użytkownika root przez SSH** – ustawienie `PermitRootLogin` no w pliku `/etc/ssh/sshd_config`. Nawet jeśli atakujący pozna hasło roota, nie będzie mógł zalogować się bezpośrednio przez SSH.
- **Wymuszenie silnych haseł** – zmiana haseł wszystkich kont systemowych na silne, unikalne hasła o długości co najmniej 16 znaków, zawierające wielkie i małe litery, cyfry oraz znaki specjalne.
- **Wyłączenie anonimowego dostępu do FTP** – ustawienie `anonymous_enable=NO` w pliku `/etc/vsftpd.conf` lub całkowite wyłączenie usługi FTP jeśli nie jest niezbędna.
- **Wdrożenie reguł zapory sieciowej UFW** – skonfigurowanie zapory UFW z zasadą domyślnego blokowania ruchu przychodzącego i zezwolenie wyłącznie na niezbędne porty (22/TCP, 80/TCP). Zablokowanie portów 21/TCP i 3306/TCP dla ruchu zewnętrznego.

Średnioterminowe (1–4 tygodnie)

Działania z tej grupy wymagają staranniejszego planowania i testowania przed wdrożeniem, jednak powinny zostać zrealizowane w krótkim czasie:

- **Wdrożenie i konfiguracja Fail2ban** – instalacja i konfiguracja narzędzia Fail2ban monitorującego logi systemowe i automatycznie blokującego adresy IP po przekroczeniu progu nieudanych prób logowania. Zalecana konfiguracja: maksymalnie 5 prób logowania, czas blokady co najmniej 1 godzina.
- **Zastąpienie FTP protokołem SFTP** – wdrożenie SFTP (SSH File Transfer Protocol) jako bezpiecznej alternatywy dla nieszyfrowanego FTP. SFTP jest wbudowany w OpenSSH i nie wymaga instalacji dodatkowego oprogramowania.

- **Ograniczenie dostępu do bazy danych MariaDB wyłącznie do localhost** – weryfikacja i utrzymanie konfiguracji `bind-address = 127.0.0.1` w pliku konfiguracyjnym MariaDB, eliminującej możliwość zdalnego dostępu do bazy danych.
- **Ograniczenie algorytmów MAC w SSH** – dodanie do pliku `/etc/ssh/sshd_config` dyrektywy `MACs hmac-sha2-256,hmac-sha2-512` w celu eliminacji słabych algorytmów MAC opartych na MD5 i SHA-1.
- **Regularne przeglądy konfiguracji usług** – wprowadzenie procedury okresowego przeglądu konfiguracji wszystkich aktywnych usług sieciowych co najmniej raz na kwartał.

Długoterminowe (1–3 miesiące i stale)

Działania z tej grupy mają charakter systemowy i organizacyjny – ich celem jest zbudowanie trwałych mechanizmów zapewniających utrzymanie wysokiego poziomu bezpieczeństwa systemu w czasie:

- **Regularne audyty bezpieczeństwa** – przeprowadzanie pełnego audytu bezpieczeństwa systemu co najmniej raz na pół roku, z uwzględnieniem skanowania podatności narzędziem OpenVAS oraz lokalnego audytu konfiguracji narzędziem Lynis.
- **Wdrożenie monitorowania logów systemowych** – konfiguracja centralnego systemu zbierania i analizy logów (np. przy użyciu narzędzi `logwatch` lub `auditd`) umożliwiającego wykrycie nieautoryzowanych prób dostępu oraz podejrzanych aktywności w czasie rzeczywistym.
- **Bieżąca aktualizacja systemu i usług** – wdrożenie polityki regularnego stosowania aktualizacji bezpieczeństwa systemu operacyjnego i zainstalowanego oprogramowania. Zaleca się włączenie automatycznych aktualizacji bezpieczeństwa przy użyciu pakietu `unattended-upgrades`.
- **Ograniczenie ujawnianych informacji o systemie** – wyłączenie nagłówek wersji w serwerze Nginx (`server_tokens off`), wyłączenie obsługi znaczników czasu TCP (`net.ipv4.tcp_timestamps=0`) oraz ograniczenie odpowiedzi ICMP przez zaporę UFW.
- **Zasada minimalnych uprawnień** – przegląd i ograniczenie uprawnień wszystkich kont użytkowników systemowych do niezbędnego minimum. Usunięcie lub zablokowanie kont nieużywanych.

Information	Results (2 of 33)	Hosts (1 of 1)	Ports (1 of 2)	Applications (4 of 4)	Operating Systems (0 of 0)	CVEs (0 of 0)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (2 of 1)	User Tags (0)
1 - 2 of 2										
Vulnerability		Severity	QoD	Host IP	Name	Location	EPSS Score	Percentile	Created	
Weak MAC Algorithm(s) Supported (SSH)		2.6 (Low)	80 %	192.168.146.128		22/tcp	N/A	N/A	Sat, Apr 18, 2026 8:47 PM Central European Summer Time	
TCP Timestamps Information Disclosure		2.6 (Low)	80 %	192.168.146.128		general/tcp	N/A	N/A	Sat, Apr 18, 2026 8:47 PM Central European Summer Time	
1 - 2 of 2										

Rysunek 38: Re-audyt – wyniki końcowe

Information	Results (2 of 33)	Hosts (1 of 1)	Ports (1 of 2)	Applications (4 of 4)	Operating Systems (0 of 0)	CVEs (0 of 0)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (1 of 1)	User Tags (0)			
1 - 1 of 1													
IP Address	Hostname	OS	Ports	Apps	Distance	Auth	Start	End	Critical	High	Medium	Low	Info
192.168.146.128			1	4			Sat, Apr 18, 2026 8:40 PM Central European Summer Time	Invalid or no date available	0	0	0	2	0
1 - 1 of 1													

(Applied filter: apply_overrides=0 levels=chd rows=100 min_app=10 first=1 sort-reverse=severity)

Copyright © 2006-2024 by Greenbone AG, www.greenbone.net

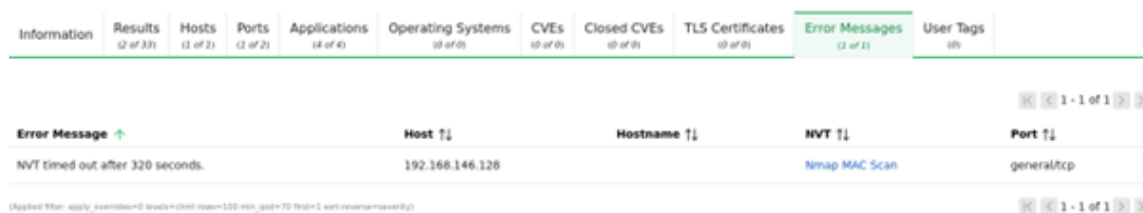
Rysunek 39: Re-audyt – host i poziomy ryzyka

Information	Results (2 of 33)	Hosts (1 of 1)	Ports (1 of 2)	Applications (4 of 4)	Operating Systems (0 of 0)	CVEs (0 of 0)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (1 of 1)	User Tags (0)
1 - 1 of 1										
Port ↑	Hosts ↑				Severity ↓					
22/tcp	1				2.6 (Low)					
(Applied filter: apply_overrides=0;level=check;rows=300;min_gaps=70;top=1;sort=reverse=severity)										
1 - 1 of 1										

Rysunek 40: Re-audyt – wykryte porty

Information	Results (2 of 33)	Hosts (1 of 1)	Ports (1 of 2)	Applications (4 of 4)	Operating Systems (0 of 0)	CVEs (0 of 0)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (2 of 1)	User Tags (0)
1 - 4 of 4										
Application CPE ↑↓	Hosts ↑↓	Occurrences ↑↓	Severity ↓							
 cpe:/a:openssh:openssh:9.6p1	1	1	N/A							
cpe:/a:libf-secure_shell_protocol:2.0	1	1	N/A							
cpe:/a:nginx:nginx:1.24.0	1	1	N/A							
cpe:/a:rs-nginx:1.24.0	1	1	N/A							
Applied filter: apply_overwrite=0 levels=child spans=100 min_app=70 top=1 sort=score+severity 1 - 4 of 4										

Rysunek 41: Re-audyt – wykryte aplikacje



Rysunek 42: Re-audyt – komunikat o timeout jednego z testów

10.2. Wyniki re-audytu

Re-audyt wykazał znaczącą poprawę poziomu bezpieczeństwa systemu w porównaniu do stanu po symulacji podatności. Podatności krytyczna i obie średnie zostały całkowicie wyeliminowane. W systemie pozostały wyłącznie dwie podatności niskiego poziomu ryzyka o charakterze informacyjnym, które nie stanowią bezpośredniego zagrożenia dla integralności ani dostępności usług.

Szczegółowe porównanie stanu systemu przed i po wdrożeniu hardeningu przedstawia poniższa tabela:

Podatność	Przed	Po
SSH Brute Force Logins With Default Credentials	Obecna (Critical)	Usunięta
Anonymous FTP Login	Obecna (Medium)	Usunięta
FTP Unencrypted Cleartext Login	Obecna (Medium)	Usunięta
TCP Timestamps Information Disclosure	Obecna (Low)	Obecna (Low)
Weak MAC Algorithms Supported (SSH)	Obecna (Low)	Obecna (Low)
ICMP Timestamp Reply Information Disclosure	Obecna (Low)	Usunięta

10.3. Ocena skuteczności hardeningu

Wdrożone działania hardeningowe okazały się w pełni skuteczne w zakresie podatności krytycznych i średnich. Spośród sześciu wykrytych podatności cztery zostały całkowicie usunięte, co stanowi 67% wszystkich wykrytych problemów bezpieczeństwa. Co istotniejsze, usunięto 100% podatności krytycznych i średnich – czyli wszystkich podatności stwarzających realne ryzyko nieautoryzowanego dostępu lub utraty danych.

Dwie pozostałe podatności niskiego ryzyka (TCP Timestamps oraz Weak MAC Algorithms) mają charakter informacyjny i ich usunięcie wymagałoby dodatkowych zmian w konfiguracji jądra systemu oraz algorytmów SSH, co wykracza poza zakres podstawowego hardeningu, lecz może zostać zrealizowane w ramach dalszych prac.

11. Wnioski końcowe

Przeprowadzony audyt bezpieczeństwa systemu Ubuntu Server pozwolił na kompleksową ocenę poziomu bezpieczeństwa środowiska serwerowego w warunkach laboratoryjnych i dostarczył praktycznych wniosków dotyczących wpływu konfiguracji usług sieciowych na bezpieczeństwo systemu.

Ocena stanu wyjściowego. System Ubuntu Server 24.04 LTS w stanie bezpośrednio po instalacji i podstawowej konfiguracji wykazał stosunkowo wysoki poziom bezpieczeństwa – brak podatności krytycznych i wysokich potwierdził, że domyślna konfiguracja systemu jest względnie poprawna. Wykryte podatności niskiego ryzyka miały charakter wyłącznie informacyjny i nie stanowiły bezpośredniego zagrożenia. Oznacza to, że sama instalacja systemu Ubuntu Server nie tworzy krytycznych luk bezpieczeństwa, jednak wymaga dalszego wzmacniania zgodnie z dobrymi praktykami administracyjnymi.

Wpływ błędnej konfiguracji. Celowe wprowadzenie słabości konfiguracyjnych – słabe hasło i włączone logowanie root w SSH oraz podatna konfiguracja FTP – spowodowało natychmiastowe pojawienie się podatności krytycznej (CVSS 9.8) i dwóch średnich (CVSS 4.8–6.4). Wynik ten jednoznacznie potwierdza, że nawet pozornie niewielkie zmiany konfiguracyjne mogą dramatycznie obniżyć poziom bezpieczeństwa systemu. Szczególnie niepokojące jest to, że podatność SSH brute force jest trywialna w eksploatacji – dostępne narzędzia automatyzują ten atak i nie wymagają zaawansowanej wiedzy technicznej od potencjalnego atakującego.

Skuteczność hardeningu. Wdrożone działania hardeningowe w pełni zrealizowały założony cel – całkowite usunięcie podatności krytycznych i średnich zostało potwierdzone przez niezależny re-audit. Szczególnie istotne było zabezpieczenie usługi SSH przez wyłączenie uwierzytelniania hasłem i blokadę konta root, wdrożenie Fail2ban jako dodatkowej warstwy ochrony oraz konfiguracja zapory UFW ograniczającej dostęp sieciowy do niezbędnego minimum.

Wnioski organizacyjne. Projekt potwierdził praktyczne znaczenie regularnych audytów bezpieczeństwa jako stałego elementu utrzymania systemów serwerowych. Nawet w prostym środowisku laboratoryjnym błędna konfiguracja kilku parametrów doprowadziła do powstania podatności umożliwiającej pełne przejęcie systemu. W środowisku produkcyjnym, gdzie systemy są dostępne z Internetu i przechowują rzeczywiste dane użytkowników,

konsekwencje takich zaniedbań mogłyby być znacznie poważniejsze. Wdrożenie procesu regularnych audytów, monitorowania logów i bieżącej aktualizacji oprogramowania stanowi minimalny standard bezpieczeństwa dla każdego środowiska serwerowego.

12. Załączniki

Poniższe załączniki zawierają materiały dowodowe dokumentujące przeprowadzony audyt. Zgodnie z wytycznymi prowadzącego strony zawierające screeny, logi i wyniki skanów nie są wliczane do minimalnej objętości raportu.

Do raportu dołączono:

- zrzuty ekranów z instalacji i konfiguracji środowiska laboratoryjnego (rysunki 1–3),
- zrzuty ekranów dokumentujące instalację i weryfikację usług sieciowych (rysunki 4–11),
- zrzuty ekranów z instalacji narzędzi audytowych i konfiguracji GVM/OpenVAS (rysunki 12–13),
- wyniki skanowania Nmap wraz z weryfikacją dostępności usług (rysunki 14–15),
- zrzuty ekranów z konfiguracji zadania skanowania OpenVAS (rysunki 16–20),
- pełne raporty OpenVAS z audytu wyjściowego (rysunki 21–27),
- pełne raporty OpenVAS ze stanu po symulacji podatności (rysunki 28–35),
- zrzuty ekranów dokumentujące proces hardeningu systemu (rysunki 36–42),
- pełne raporty OpenVAS z re-audytu po wdrożeniu hardeningu (rysunki 43–49).